

Project: **Wi-Fi Security Protocols and Enterprise Authentication using 802.1X and RADIUS**

Release: Final version

Date: April 16, 2026

Product Title: **Evolution of Wi-Fi Security Protocols and Enterprise Authentication using 802.1X and RADIUS**

Authors: Carolyn Mah, Lovepreet Sidhu, Harris Waheed

Client: INFO 4370 – S50 – Group 5

Document Ref: Product description

Version No: 1.0

1. PRODUCT DESCRIPTION HISTORY

1.1 Revision History

Revision date	Previous revision date	Summary of Changes	Changes marked
April 3, 2026		Creation of document	
April 6, 2026	April 3, 2026	Addition to Wi-Fi security protocols section	
April 7, 2026	April 6, 2026	Addition and changes to Wi-Fi security protocols section	
April 8, 2026	April 7, 2026	Addition and changes to Wi-Fi security protocols section	
April 9, 2026	April 8, 2026	Addition and changes to Wi-Fi security protocols section	
April 10, 2026	April 9, 2026	Addition and changes to Wi-Fi security protocols section; Addition to RADIUS section	
April 11, 2026	April 10, 2026	Addition and changes to RADIUS section	
April 13, 2026	April 11, 2026	Addition and changes to RADIUS section	
April 15, 2026	April 13, 2026	Addition and changes to RADIUS section; format change and addition to document information	
April 16, 2026	April 15, 2026	Final review and changes to document content and format	

1.2 Approvals (Proj. Manager only)

This document requires the following approvals.

Name	Signature	Title	Date of Issue	Version
Lovepreet Sidhu	Lovepreet Sidhu	Project Manager	April 16, 2025	1.0

1.3 Distribution

The following people/groups will receive a copy of this document:

Name	Title	Date Issue	of	Version
Cesar Lopez Castellanos	Stakeholder	April 15, 2026		1.0

Table of Contents

1. PRODUCT DESCRIPTION HISTORY.....	2
1.1 Revision History	2
1.2 Approvals (Proj. Manager only).....	2
1.3 Distribution.....	3
1. OVERVIEW.....	6
2.1 Identifier	6
2.2 Title	6
1.4 Purpose.....	6
2.2.1 Introduction to Wi-Fi Security Protocols	6
a) WEP.....	6
b) WPA.....	7
c) WPA2.....	7
d) WPA3.....	8
e) Transition to Enterprise Authentication	9
f) AAA Framework	9
g) 802.1X and EAP.....	9
2.2.2 RADIUS	10
2.3 Composition	10
2.3.1 Authentication Methods Comparison Table	10
2.3.2 Lab Environment.....	11
2.3.3 Infrastructure Overview	11
2.3.4 Section Achievements	12
2. USING THE PRODUCT/SERVICE	13
3.1 How to install your product	13
3.1.1 Phase 1 - Local NPS/RADIUS Setup	13
3.1.1.1 Installing the NPS Role.....	13
Step 1 - Installation Type.....	13
Step 2 - Server Selection	13
Step 3 - Adding Required Features.....	14
Step 4 - Features Page.....	15
Step 5 - NPS Role Description	16
Step 6 - Installation Progress.....	17

Step 7 - NPS Console Opens.....	18
3.1.1.2 Configuring a RADIUS Client	19
3.1.1.3 Creating a Test User	20
3.1.2 Phase 2 Azure Enterprise Setup (AD + CA + NAS + EAP-TLS).....	22
3.1.2.1 Active Directory and NPS Installation	22
a) AD DS Installation Success.....	22
b) Active Directory User Creation	22
3.1.2.2 Registering the Linux NAS as a RADIUS Client	23
a) NAS-Linux.....	23
3.1.2.3 Certificate Authority and Certificate Issuance	24
a) Certificate Authority Configuration	24
b) Certificate Issuance	25
c) Certificate Enrollment (Client Side).....	27
3.1.2.4 NPS Network Policy - EAP-TLS Configuration	28
h) EAP-TLS.....	28
i) 802.1X Supplicant Configuration on Client VM	29
3.1.3 Final System Behavior	30
a) Live enterprise deployment.....	30
Supplicant.....	30
Authenticator	31
Authentication Server	31
The Full EAP-TLS Authentication Flow in Production.....	31
Contrast with PEAP	32
3.2 Security recommendations.....	32
3.3 Instructions for use	34
3.3.1 Testing with NTRadPing and Wireshark.....	35
3.3.2 Successful Authentication - Event Viewer	36
3.3.3 Confirmed Successful Exchange (NTRadPing + Wireshark).....	36
3.3.4 Phase 1 Summary.....	37
3.3.5 Testing from Linux NAS - radtest Results	38
3.3.6 Event Viewer - Rejection Confirmed	38
3.3.7 Conclusion: Why Full EAP-TLS Testing Could Not Be Completed.....	39
3. References.....	41

1. OVERVIEW

2.1 Identifier

INFO4370-Section50-Team5

2.2 Title

Enterprise Wi-Fi Authentication using RADIUS and EAP-TLS

1.4 Purpose

This section presents the evolution of Wi-Fi security protocols and examines how modern enterprise networks implement secure authentication mechanisms. While early wireless security protocols focused primarily on encryption, they lacked centralized identity-based access control. To address these limitations, enterprise environments adopt authentication frameworks based on the AAA (Authentication, Authorization, and Accounting) model. This section therefore progresses from traditional Wi-Fi security protocols (WEP, WPA, WPA2, WPA3) to enterprise authentication mechanisms using 802.1X and RADIUS, with a primary focus on authentication.

2.2.1 Introduction to Wi-Fi Security Protocols

Wi-Fi security is a necessity to ensure that all devices connected to the wireless network are protected from possible risks and attacks of malicious users. If unsecured, the data shared across the network may easily become compromised and collected by third parties; this includes sensitive business data and personal information that should be kept private. Among the many ways to keep a wireless network secure, there exists many types of security protocols designed for the very purpose of preventing unauthorized access to the wireless network.

a) WEP

Wired Equivalent Privacy (WEP) is an obsolete security protocol originally introduced in 1997 in an attempt at securing wireless networks. Data transmitted across the wireless local area network (WLAN) was encrypted using a 64- or 128-bit static key in an attempt to prevent man-in-the-middle attacks, where eavesdroppers could intercept, read, and alter the client's data.

WEP uses an RC4 algorithm for encryption, where the client device encrypts data using a shared key which is sent to the destination router who decrypts the message using the same shared key. The encrypted packet consists of the shared key (password) and a random 24-bit initialization vector (IV) generated by WEP, creating a unique key stream to combine with the plaintext packet in order to encrypt it.

b) WPA

Wi-Fi Protected Access (WPA) was released in 2003 as the successor to WEP, with 256-bit key encryption as opposed to WEP's 64- or 128-bit encryption. Alongside the increased key size, WPA contains new security mechanisms.

The Temporal Key Integrity Protocol (TKIP) used by WPA dynamically generates a different 128-bit key for each packet, preventing attacks caused by WEP's static key system. WPA also includes a message integrity check (MIC) mechanism, providing stronger data integrity to prevent the alteration of encrypted messages, stopping man-in-the-middle attacks that were common with WEP.

c) WPA2

Wi-Fi Protected Access 2 (WPA2) is the updated version of WPA released in 2004 with a stronger encryption protocol allowing for stronger security on the wireless network. WPA2 utilizes the Counter Mode Cipher Block Chaining Message Authentication Code Protocol (CCMP), a security protocol following the Advanced Encryption Standard (AES), replacing the previously used TKIP to provide more reliable message authenticity and integrity verification.

WPA2 has two usable modes depending on the network type; WPA2-Personal which is typically used in home or small office environments, and WPA-Enterprise which is more suited for larger businesses and organizations.

WPA2-Personal

WPA2-Personal uses a pre-shared key (PSK) to authenticate devices attempting to connect to the wireless network. The PSK, or password, is a shared secret that both the router and the connecting device are to know in advance. The PSK authentication mechanism allows devices to securely connect to the network without transmitting it, preventing attackers from eavesdropping.

The router is configured with the passphrase, which is converted to a 256-bit key referred to as the Pairwise Master Key (PMK); the PMK is used to authenticate connecting devices without having to transmit the password over air. Authentication is done through a 4-way handshake, which starts once the connecting device sends a request after attempting to join the network.

The 4-Way Handshake

The router begins the 4-way handshake by sending a random number (Anonce) it generated; on the client's side, the device has also generated a random number (Snonce). The client device has the PMK, Snonce and the client's MAC address, and will have the Anonce and the router (Access Point or AP)'s MAC address after receiving the first message. The Pairwise Transient Key (PTK) can be derived using these keys, which will be used to encrypt transmission between the client and AP.

The client then sends a message to the AP with the Snonce and a Message Integrity Check (MIC) value meant to protect the message from tampering; the MIC is calculated using the Key Confirmation Key (KCK), a 128-bit key using bits 0-127 of the PTK. Once the AP receives the message, it uses the KCK to calculate a MIC value and compare it to the received MIC from the client. A matching MIC means that both the client and the AP have the same PMK, and the AP can now derive the PTK with the received Snonce.

The AP sends another message to the client containing a key installation request, a MIC, and a Group Temporal Key (GTK) which is derived from a Group Master Key (GMK), a 128-bit key randomly created by the authenticator. The client checks the MIC after receiving the message to ensure the validity and installs the PTK and GTK before sending a final message with an MIC and an acknowledgement (ACK), indicating that the client will use the installed keys to encrypt any following messages. The AP will compare the MIC in the received message and will also install the PTK and GTK. This concludes the 4-way handshake, with the client and AP transmitting encrypted frames with integrity checks.

WPA2-Enterprise

WPA2-Enterprise uses an authentication framework based on the Extensible Authentication Protocol (EAP), containing methods including EAP-Transport Layer Security (TLS), EAP-Tunneled Transport Layer Security (TTLS) and Protected Extensible Authentication Protocol (PEAP). The type of method used for authentication depends on the user, and different users may need to use different authentication methods to connect to the network.

Rather than having one shared password like with WPA2-Personal, WPA2-Enterprise uses individual credentials for each device and requires the use of a Remote Authentication Dial-In User Service (RADIUS) server containing a separate directory containing user and device information to verify the validity of the credentials. After initiating the authentication and receiving an identity request from the AP, the client device sends their credentials to the AP, which is then transmitted to the RADIUS server for verification. The RADIUS server then returns with an Access-Accept or Access-Reject and, if accepted, the RADIUS server also shares the securely generated PMK with the AP.

After a successful EAP authentication, the AP initiates a 4-way handshake with the client device in the same way it is done with WPA2-Personal.

d) WPA3

WPA3-Personal

Wi-Fi Protected Access 3 (WPA3) was released by the Wi-Fi Alliance in 2018 and is designed to be an improvement to WPA2, addressing its vulnerabilities with a more secure encryption and increased protection for data and simple passwords. WPA3 supports longer encryption keys; while WPA2 uses 128-bit keys, WPA3 uses 192-bit for personal mode and 256-bit for enterprise mode, reducing the likelihood of forcible decryption.

Simultaneous Authentication of Equals (SAE)

For WPA3-Personal, PSK is replaced with Simultaneous Authentication of Equals (SAE), generating a new unique key for each session from the passphrase rather than using the PSK as the encryption key for each device. As each client has a unique key, attackers cannot make continuous instantaneous attempts at brute-forcing the password after obtaining the key as each unique key only allows one guess at a time.

SAE-PK (SAE-Public Key)

In order to prevent newer attacks, the SAE protocol has been enhanced to SAE-PK (SAE-Public Key) adding public key cryptography with a unique key pair. The public key in this has a fingerprint associated with the password to ensure a rogue AP is not associated with the network.

WPA3-Enterprise

Enterprise Wi-Fi like WPA3-Enterprise and WPA2-Enterprise are mainly used in large organizations where a RADIUS server is used to manage many associated devices, and stronger access control and security measures are needed. In contrast to personal Wi-Fi, enterprise setups utilize the 802.1X protocol to authenticate user credentials. WPA3-Enterprise also has the option of being part of a network with virtual servers in the cloud.

e) Transition to Enterprise Authentication

While modern protocols such as WPA2 and WPA3 significantly improve encryption and data protection, they do not provide centralized identity-based authentication required in enterprise environments.

To address these limitations, organizations adopt authentication frameworks based on the AAA (Authentication, Authorization, and Accounting) model. AAA enables centralized control over user identity verification, access policies, and activity monitoring, which is essential for large-scale secure networks.

f) AAA Framework

The AAA framework consists of three core components:

- Authentication – verifies the identity of a user or device
- Authorization – determines what resources the authenticated entity can access
- Accounting – records and tracks user activity for auditing purposes

In this project, the primary focus is on authentication, where user identity is validated using RADIUS. Authorization is implemented through network policies configured in NPS, while accounting is minimally represented through system logs such as Event Viewer.

g) 802.1X and EAP

Enterprise networks implement AAA using the IEEE 802.1X framework, which provides port-based network access control. It introduces three key components:

- Supplicant – the client device requesting access

- Authenticator – the network device (e.g., access point or switch)
- Authentication Server – typically a RADIUS server

The 802.1X framework uses the Extensible Authentication Protocol (EAP), which supports multiple authentication methods such as EAP-TLS, PEAP, and TTLS. These methods allow secure communication between the client and the authentication server.

2.2.2 RADIUS

Introduction

This project presents the design, configuration, and testing of a RADIUS (Remote Authentication Dial-In User Service) authentication infrastructure implemented in two phases on Microsoft Azure. RADIUS provides centralized authentication, authorization, and accounting (AAA) for network access and is commonly used in enterprise Wi-Fi (WPA2/WPA3-Enterprise), VPNs, and 802.1X environments.

In Phase 1, a basic RADIUS environment was established using a single Windows Server virtual machine running Network Policy Server (NPS). Authentication was tested locally using PAP to validate core RADIUS functionality, with packet captures confirming successful request–response behavior and revealing that PAP exposes credentials in a weakly protected format.

In Phase 2, the environment was expanded into a realistic enterprise architecture by integrating Active Directory, a Certificate Authority, and a Linux-based Network Access Server (NAS). PAP was replaced with EAP-TLS, enabling mutual certificate-based authentication and eliminating reliance on passwords, significantly improving resistance to credential theft, brute-force attacks, and man-in-the-middle attacks.

2.3 Composition

This section describes the key components, authentication methods, and infrastructure used to implement the RADIUS-based authentication system across both phases of the project.

2.3.1 Authentication Methods Comparison Table

EAP Type	Security Level	Certificates Required	Used in Project	Notes
PAP	Very Low	No	Yes (Phase 1)	Plaintext credentials, used for basic RADIUS testing
PEAP	Medium	Server only	No	Uses TLS tunnel with inner password authentication
EAP-TLS	High	Server + Client	Yes (Phase 2)	Mutual certificate-based authentication (most secure)

2.3.2 Lab Environment

The lab environment was implemented in two phases, each with different levels of complexity and infrastructure.

Phase 1 - Windows Server Lab

Component	Details
Server Name	radius-lab
Role Installed	Network Policy and Access Services (NPS)
Auth Method	PAP
Test Tool	NTRadPing
Capture Tool	Wireshark

Phase 2 - Azure Cloud Lab

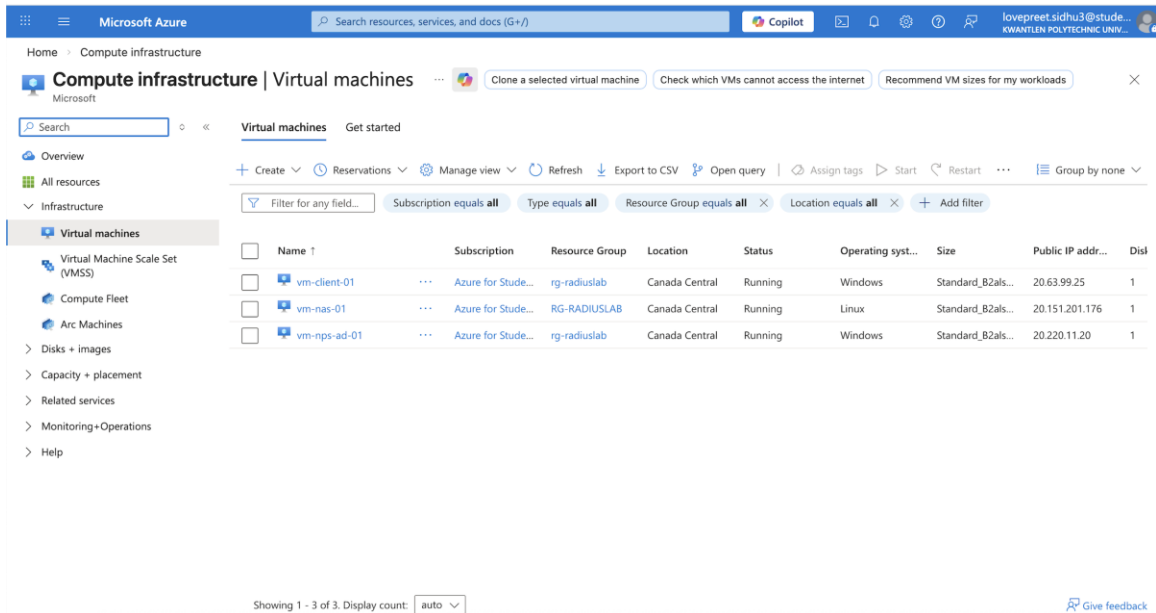
The following table summarizes the Azure-based lab environment and its mapping to the 802.1X authentication model.

VM Name	OS	Role	Role in Network Simulation
vm-client-01	Windows	End User Client	Supplicant (initiates authentication request)
vm-nas-01	Linux	NAS / RADIUS Client	Authenticator (forwards requests to RADIUS server)
vm-npsad-01	Windows Server	NPS + Active Directory + CA	Authentication Server (RADIUS – validates credentials)

Authentication Flow: Supplicant (vm-client-01) → Authenticator (vm-nas-01) → Authentication Server (vm-npsad-01) → Access Granted / Denied

2.3.3 Infrastructure Overview

The screenshot below shows all three virtual machines running simultaneously in the Azure portal, confirming the live deployment of the Canada Central environment.



[Screenshot- Azure portal showing all three VMs running]

2.3.4 Section Achievements

- Deployed a **three-tier Azure infrastructure** consisting of a Windows client VM acting as the **supplicant**, a Linux NAS acting as the **authenticator** (Network Access Server), and a Windows Server (NPS/Active Directory/Certificate Authority) acting as the **RADIUS authentication server** in the Canada Central region
- Configured **Active Directory with the domain** radiuslab.local and created a **domain user account** testad_u1
- Installed and configured an internal **Certificate Authority** (radiuslab-npsad01-CA) on the NPS server
- **Issued a user certificate** to testad_u1 using the **RADIUS-TLS-User template**, valid from March 22, 2026 to March 22, 2027
- Verified that the **certificate was successfully enrolled and available in the client machine's personal certificate store**
- Registered the **Linux NAS (vm-nas-01)** with IP address 10.20.3.4 as a **RADIUS client** in NPS using a shared secret
- Configured an **NPS network policy** named Allow-Test that enforces **EAP-TLS exclusively**, with all weaker authentication methods disabled
- Confirmed correct **policy enforcement** using **Event ID 6273 with Reason Code 66**, showing that **PAP authentication attempts were rejected** after enforcing EAP-TLS
- Verified **RADIUS connectivity using radtest** from the Linux NAS, confirming communication between the NAS and NPS server

2. USING THE PRODUCT/SERVICE

3.1 How to install your product

The installation of this system follows a **two-phase approach**:

- Phase 1 – **Basic RADIUS setup** using NPS and PAP authentication
- Phase 2 – **Enterprise implementation** using Active Directory, Certificate Authority, and EAP-TLS

The following steps outline the full deployment process.

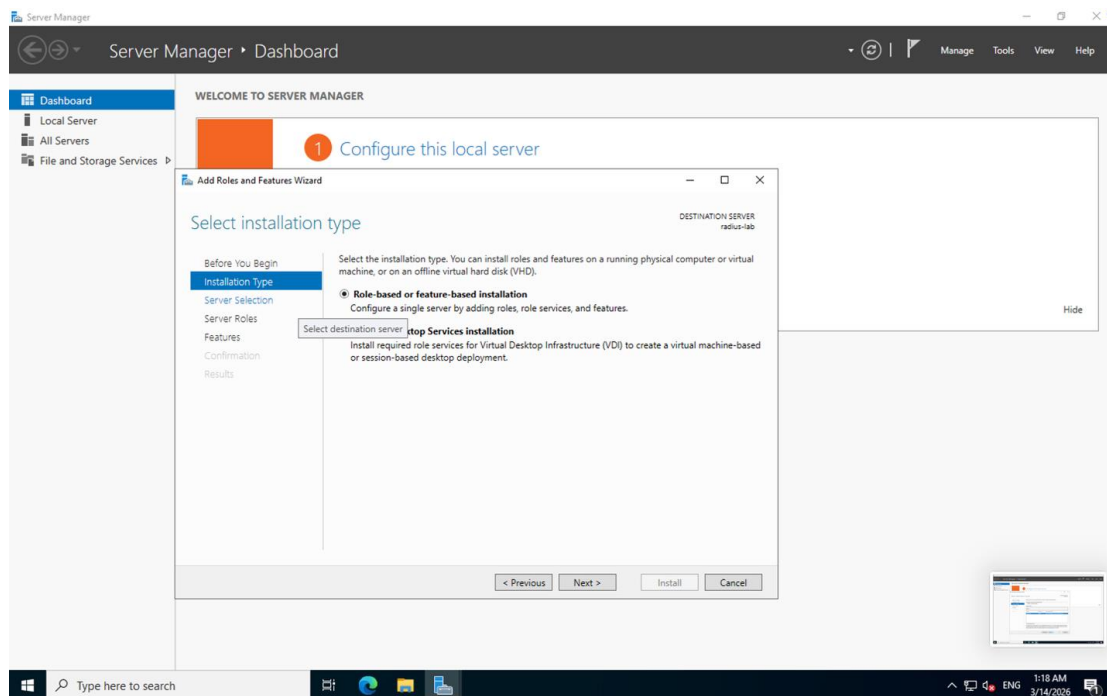
3.1.1 Phase 1 - Local NPS/RADIUS Setup

3.1.1.1 Installing the NPS Role

The Network Policy and Access Services role was installed on the Windows Server (radius-lab, IP 10.0.0.4, running Windows Server 2022 Datacenter) using the Add Roles and Features Wizard in Server Manager. The full installation process is documented below.

Step 1 - Installation Type

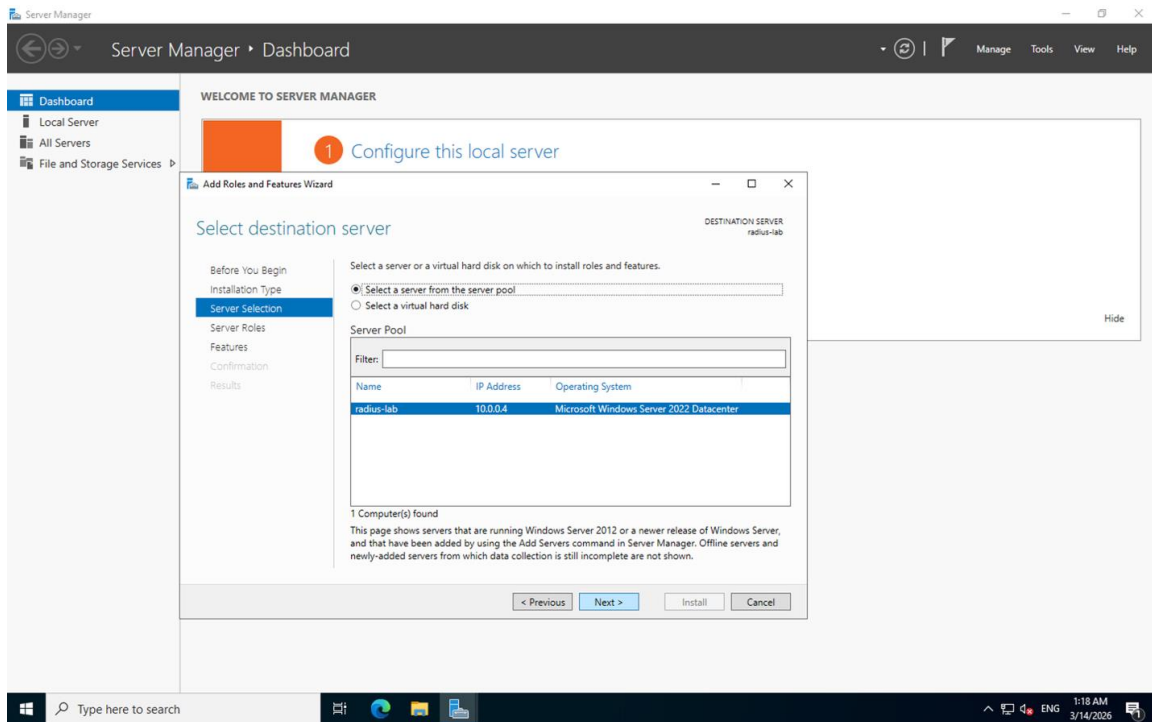
The wizard was launched and "Role-based or feature-based installation" was selected, which configures a single server by adding roles and features.



[Screenshot- Installation Type screen showing Role-based selected]

Step 2 - Server Selection

The destination server radius-lab at IP 10.0.0.4 was selected from the server pool.

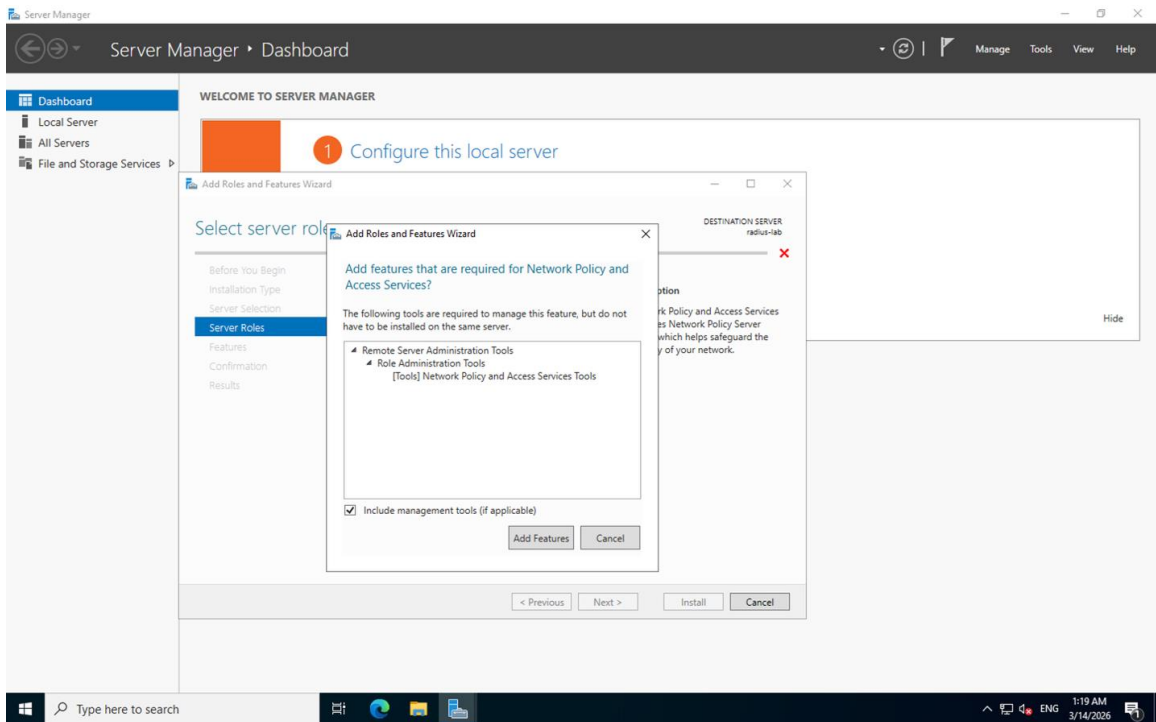


[Screenshot- Server Selection showing radius-lab highlighted]

Step 3 - Adding Required Features

After selecting the Network Policy and Access Services role under Server Roles, the wizard prompted to add required management tools. "Add Features" was clicked to include:

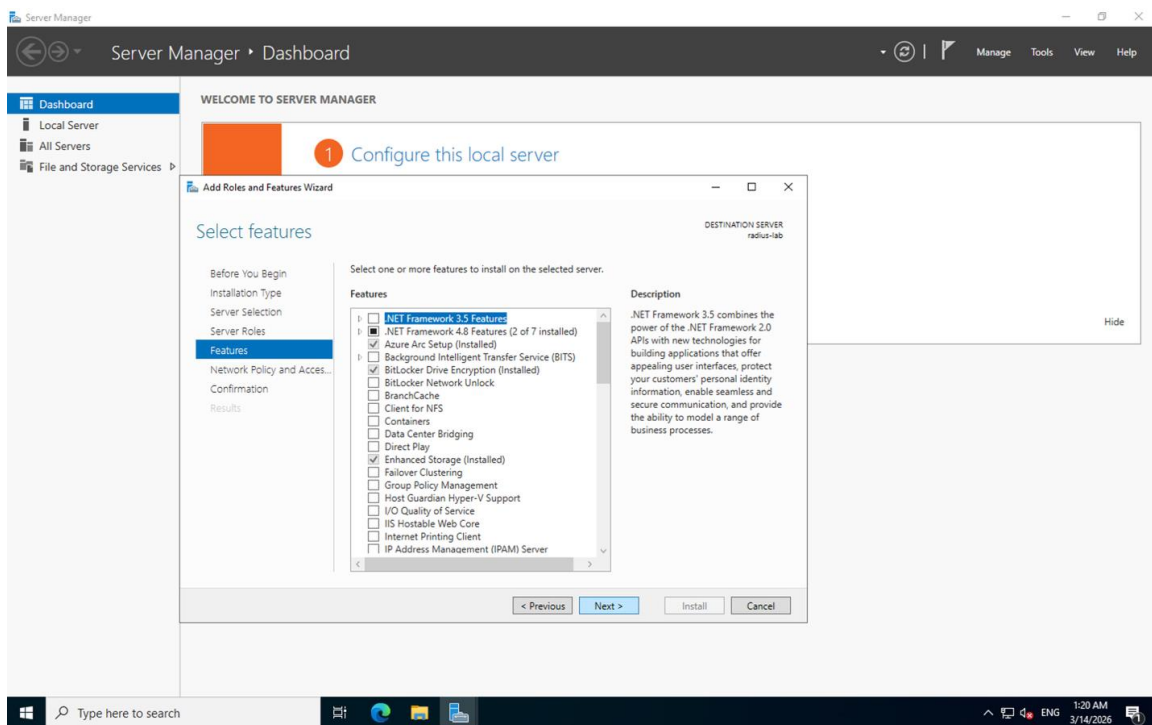
- Remote Server Administration Tools
- Role Administration Tools
- Network Policy and Access Services Tools



[Screenshot- Pop-up asking to add features required for NPS, showing management tools list]

Step 4 - Features Page

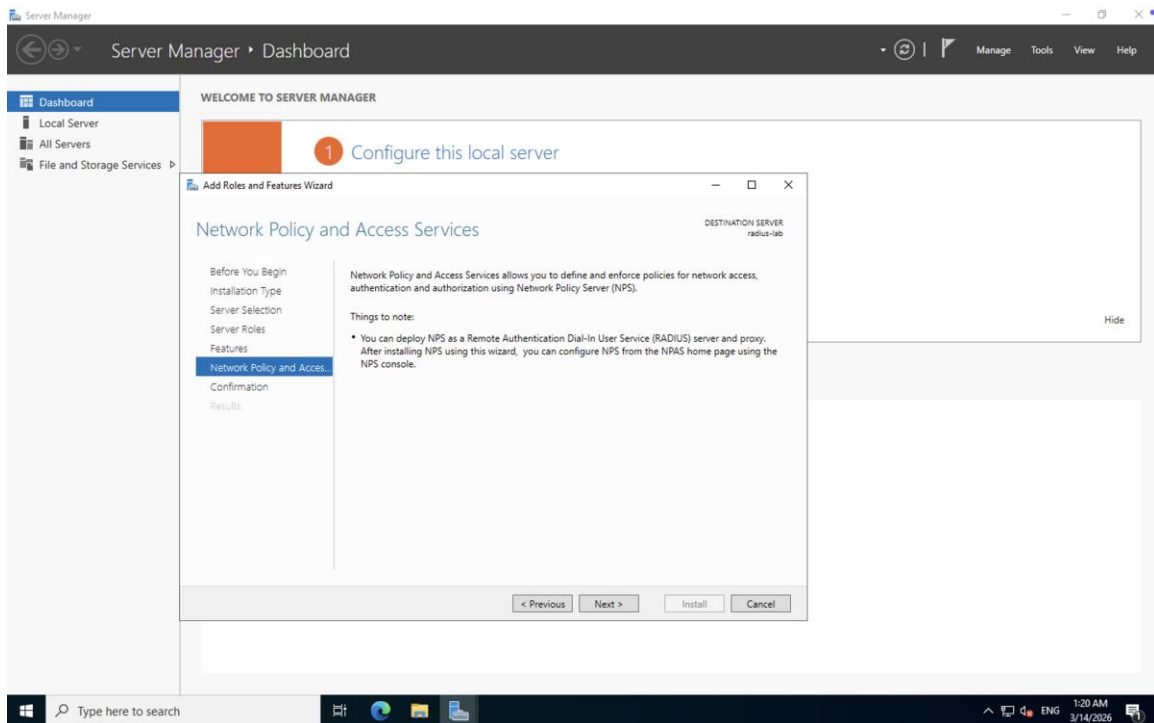
The Features page was reviewed. No additional features beyond the defaults were required for the NPS role.



[Screenshot- Select Features screen showing default features list]

Step 5 - NPS Role Description

The wizard displayed the Network Policy and Access Services description page, confirming NPS can be deployed as a RADIUS server and proxy, configurable via the NPAS console after installation.

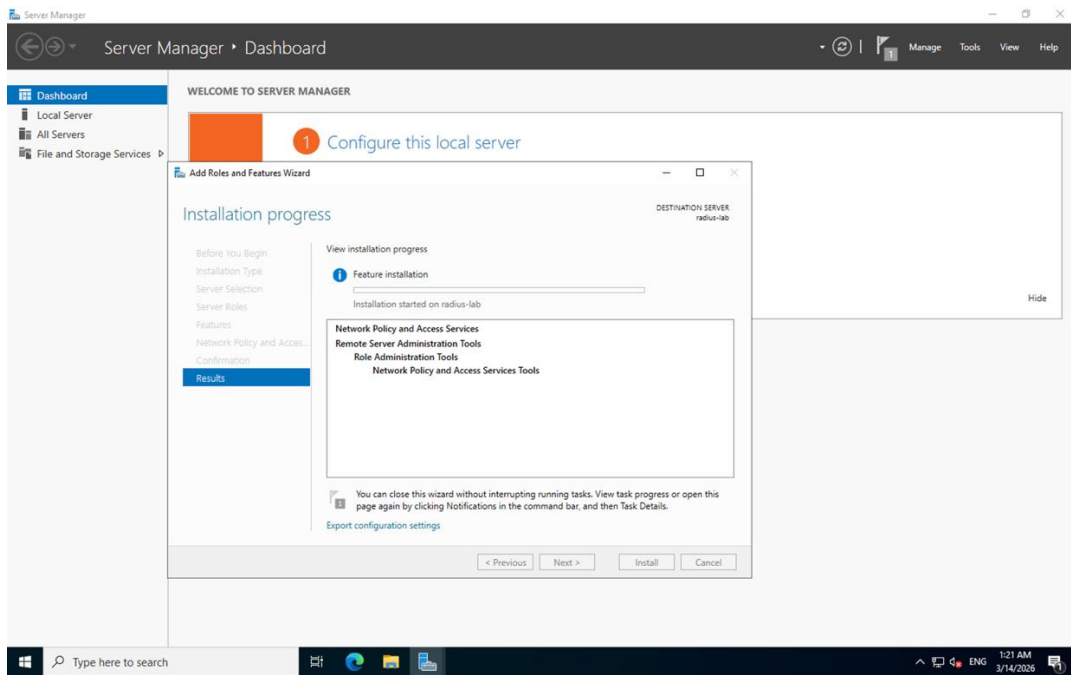


[Screenshot- Network Policy and Access Services description page]

Step 6 - Installation Progress

Installation was initiated. The wizard showed the following components being installed on radius-lab:

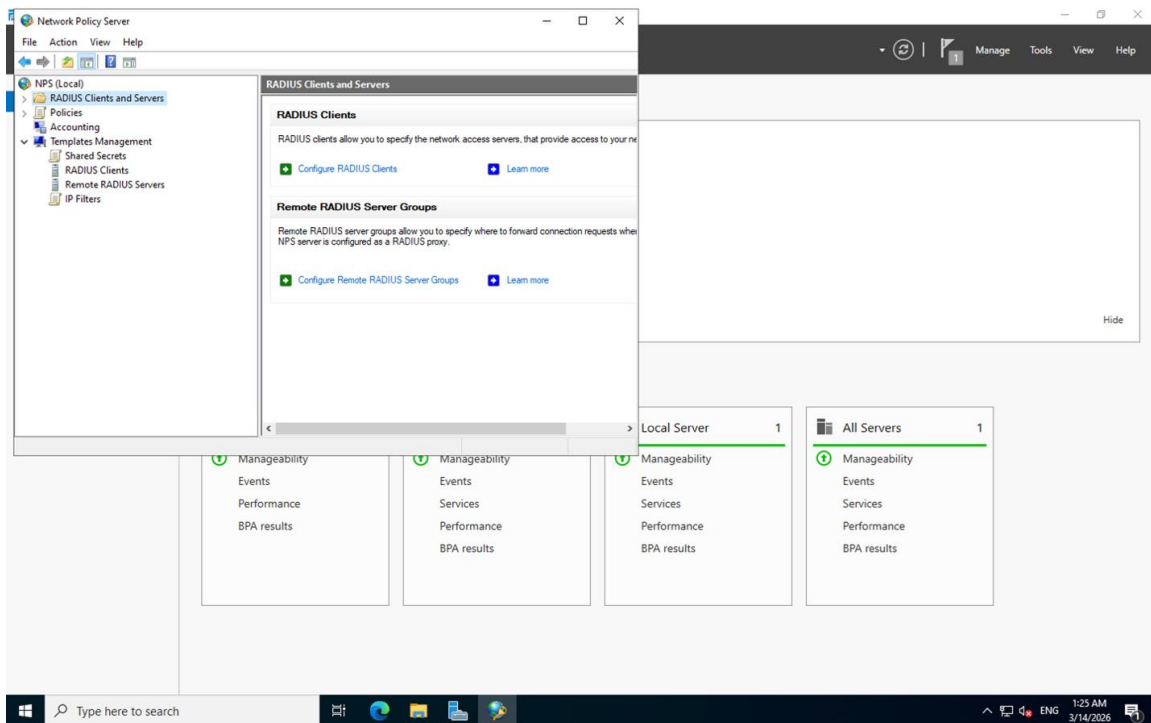
- Network Policy and Access Services
- Remote Server Administration Tools
- Role Administration Tools
- Network Policy and Access Services Tools



[Screenshot- Installation progress screen showing components installing]

Step 7 - NPS Console Opens

After installation completed, the Network Policy Server (NPS) console was launched, confirming the role was successfully installed. The console showed the RADIUS Clients and Servers section with options to configure RADIUS Clients and Remote RADIUS Server Groups.



[Screenshot- NPS console open showing RADIUS Clients and Servers tree]

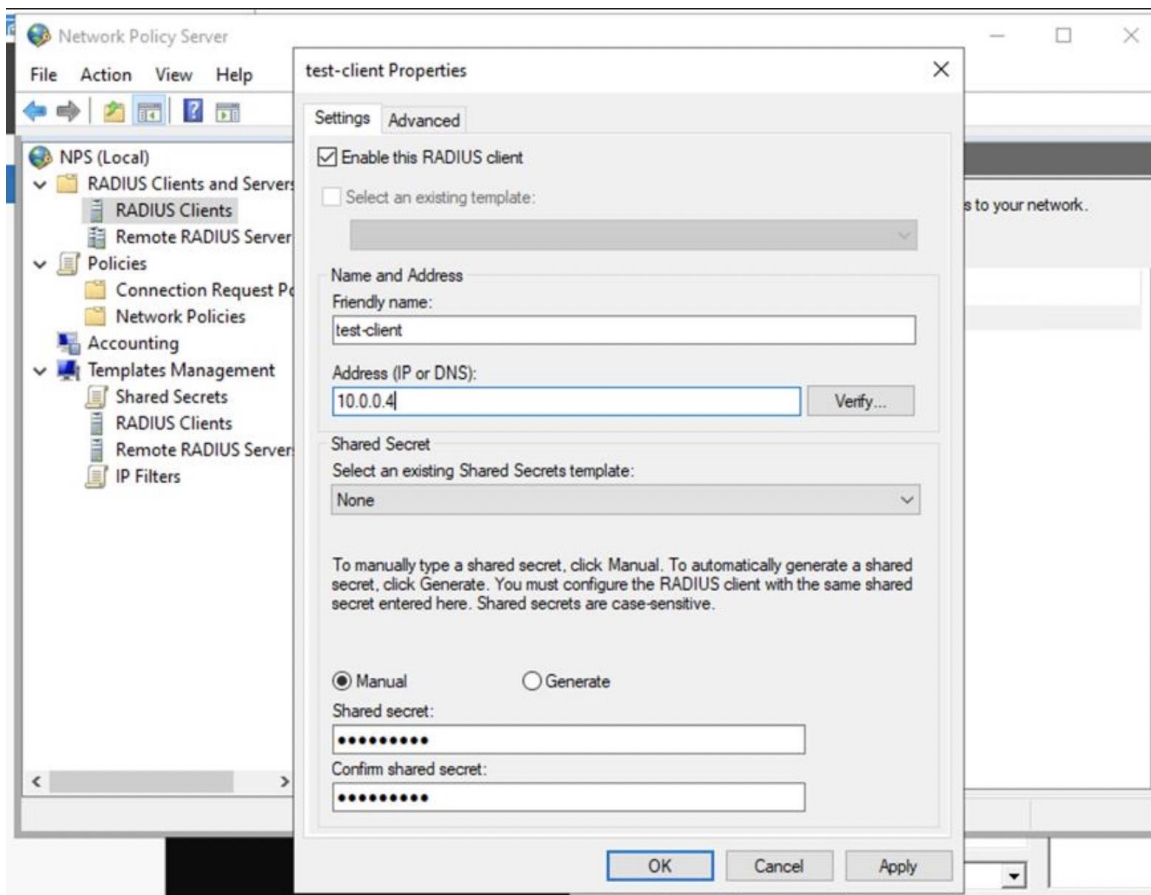
NPS allows the server to function as a RADIUS server, handling authentication requests from network devices and validating credentials against Active Directory.

3.1.1.2 Configuring a RADIUS Client

A RADIUS client named "test-client" was added in the NPS console with:

- IP Address: 10.0.0.4
- Shared Secret: manually configured (case-sensitive)

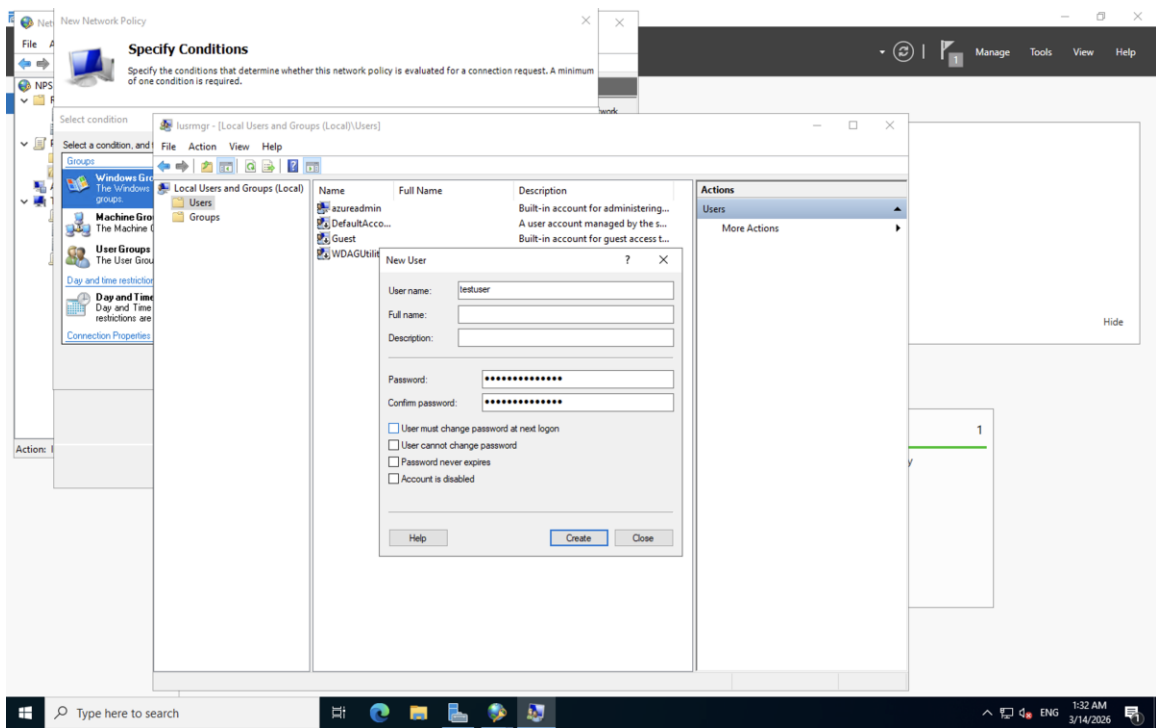
The shared secret must match exactly on both the NPS server and the RADIUS client device.



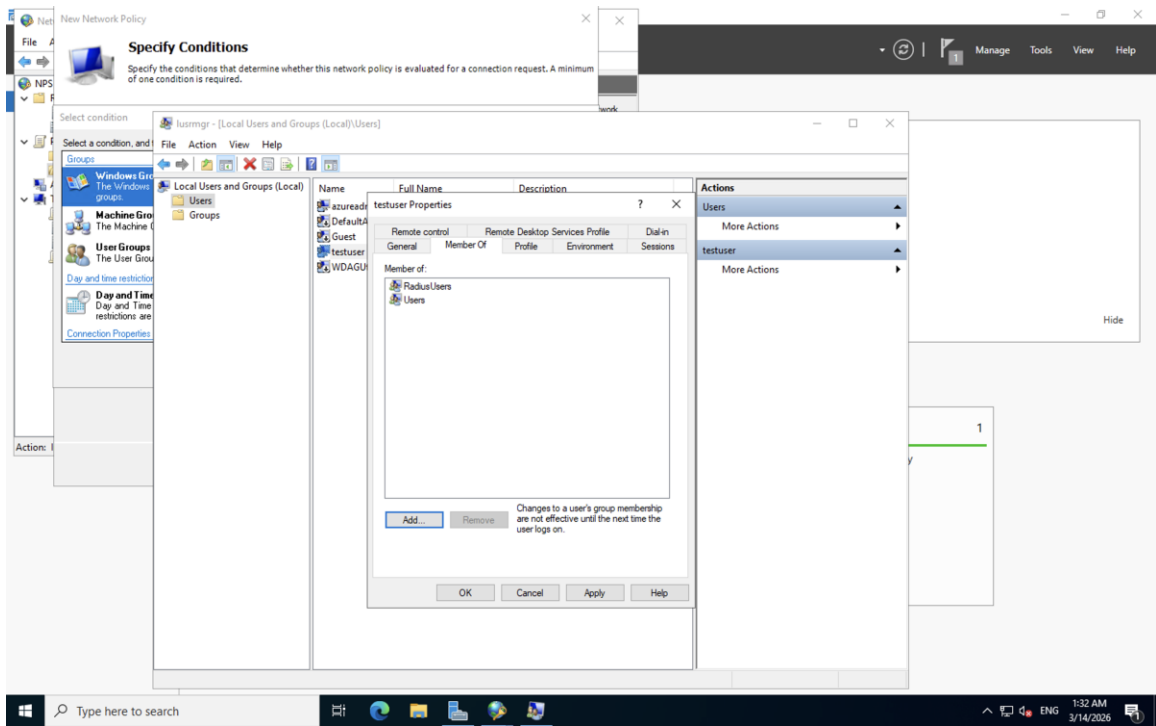
[Screenshot- NPS console showing test-client properties with IP 10.0.0.4 and shared secret fields]

3.1.1.3 Creating a Test User

A local test user named testuser was created and added to the RadiusUsers security group. Group membership is required for the NPS network policy to match and grant access.



[Screenshot- New User dialog creating testuser]



[Screenshot- testuser Properties showing Member Of: RadiusUsers and Users]

3.1.2 Phase 2 Azure Enterprise Setup (AD + CA + NAS + EAP-TLS)

3.1.2.1 Active Directory and NPS Installation

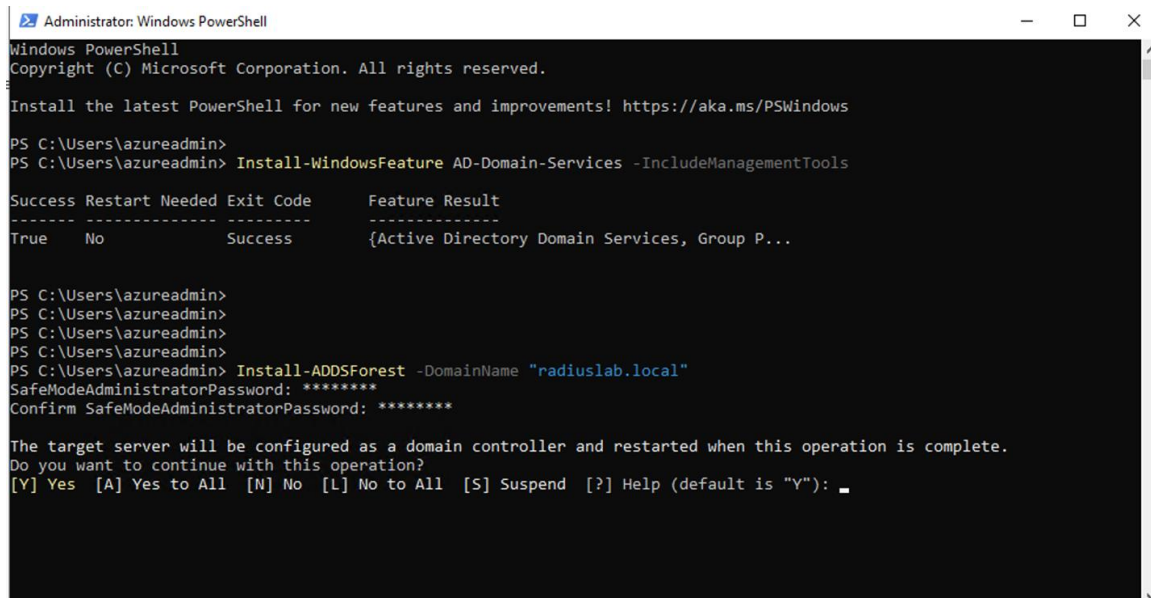
a) AD DS Installation Success

Before configuring RADIUS, Active Directory Domain Services (AD DS) was installed and a new forest was created using PowerShell on vm-npsad-01. The following commands were executed:

Install-WindowsFeature AD-Domain-Services -IncludeManagementTools

Install-ADDSForest -DomainName "radiuslab.local"

The AD DS installation completed successfully, and the server was promoted to a Domain Controller for the radiuslab.local domain. After this, the Network Policy Server (NPS) role was installed using Server Manager on the same system.



```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\azureadmin>
PS C:\Users\azureadmin> Install-WindowsFeature AD-Domain-Services -IncludeManagementTools

Success Restart Needed Exit Code      Feature Result
-----
True      No          Success      {Active Directory Domain Services, Group P...

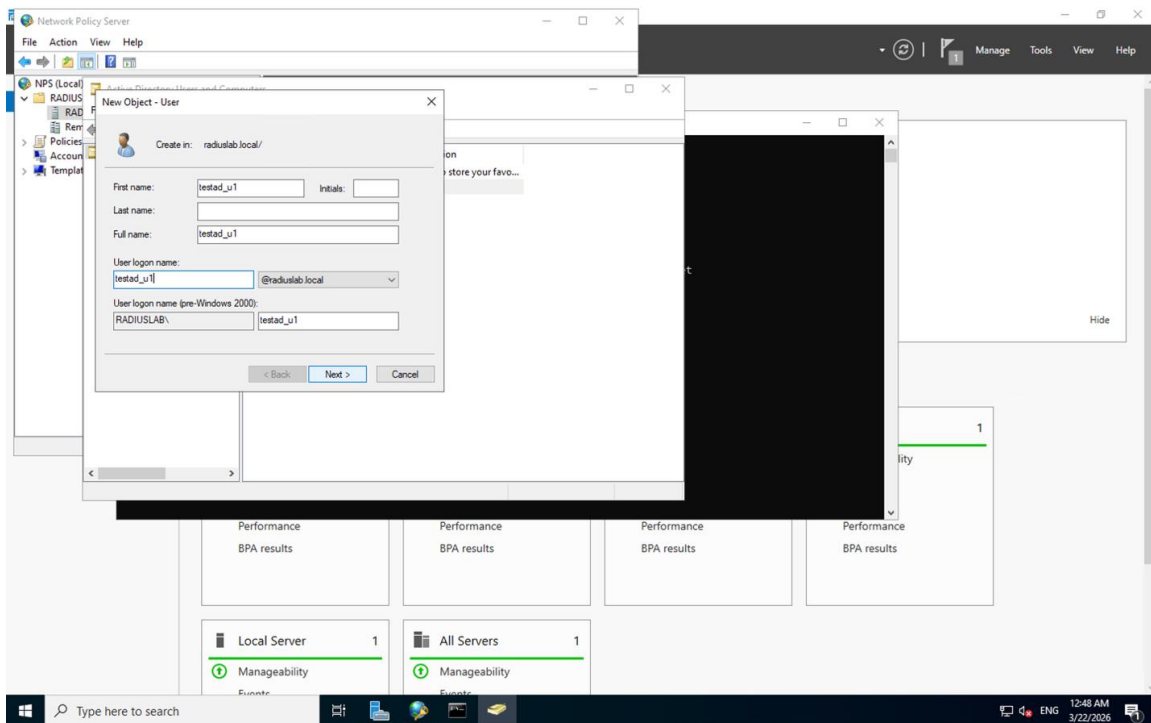
PS C:\Users\azureadmin>
PS C:\Users\azureadmin>
PS C:\Users\azureadmin>
PS C:\Users\azureadmin>
PS C:\Users\azureadmin> Install-ADDSForest -DomainName "radiuslab.local"
SafeModeAdministratorPassword: *****
Confirm SafeModeAdministratorPassword: *****

The target server will be configured as a domain controller and restarted when this operation is complete.
Do you want to continue with this operation?
[Y] Yes  [A] Yes to All  [N] No  [L] No to All  [S] Suspend  [?] Help (default is "Y"): _
```

[Screenshot- PowerShell showing AD DS installation success and ADDSForest creation for radiuslab.local]

b) Active Directory User Creation

A domain user account named testad_u1 was created in Active Directory Users and Computers under the radiuslab.local domain. This account was used as the test user for EAP-TLS authentication and serves as the Phase 2 equivalent of the local testuser account from Phase 1. Unlike the previous phase, this account is a domain-based identity authenticated through Active Directory.

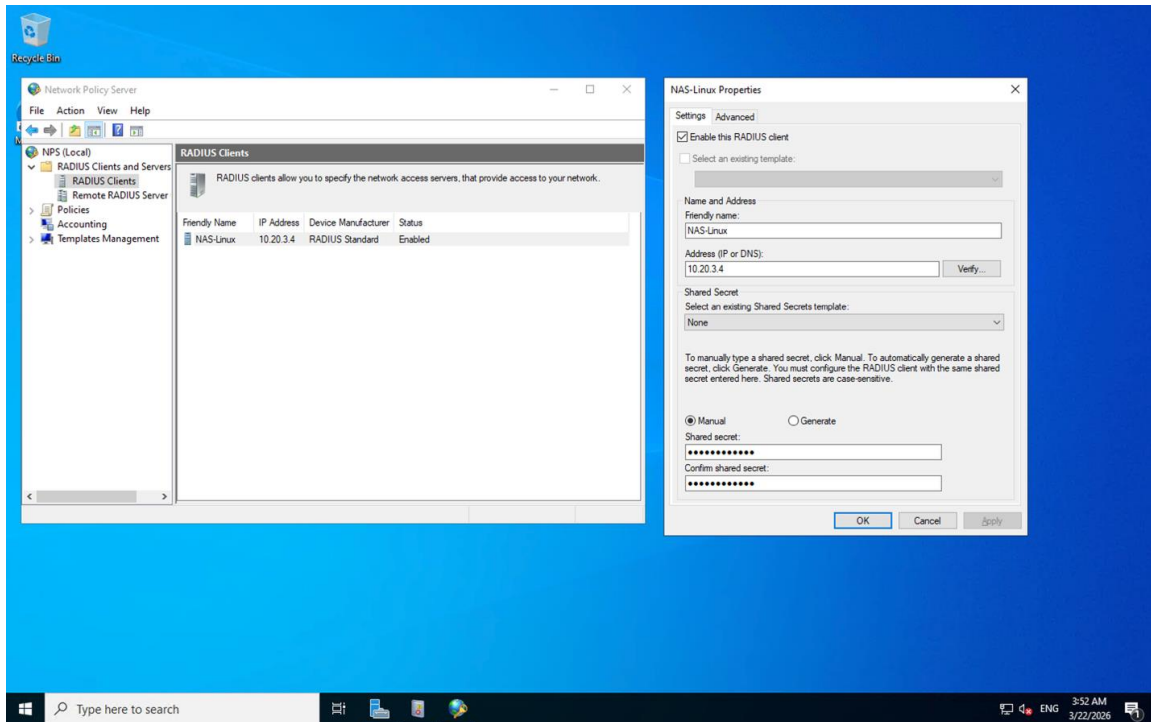


[Screenshot- Active Directory New Object - User dialog showing testad_u1 being created in radiuslab.local]

3.1.2.2 Registering the Linux NAS as a RADIUS Client

a) NAS-Linux

The Linux virtual machine vm-nas-01 with IP address 10.20.3.4 was registered in the NPS console as a RADIUS client named NAS-Linux. A shared secret was manually configured to secure communication between the NAS and the RADIUS server. This follows the same process used in Phase 1, but now utilizes a real Linux system acting as the Network Access Server instead of a Windows-based testing tool.



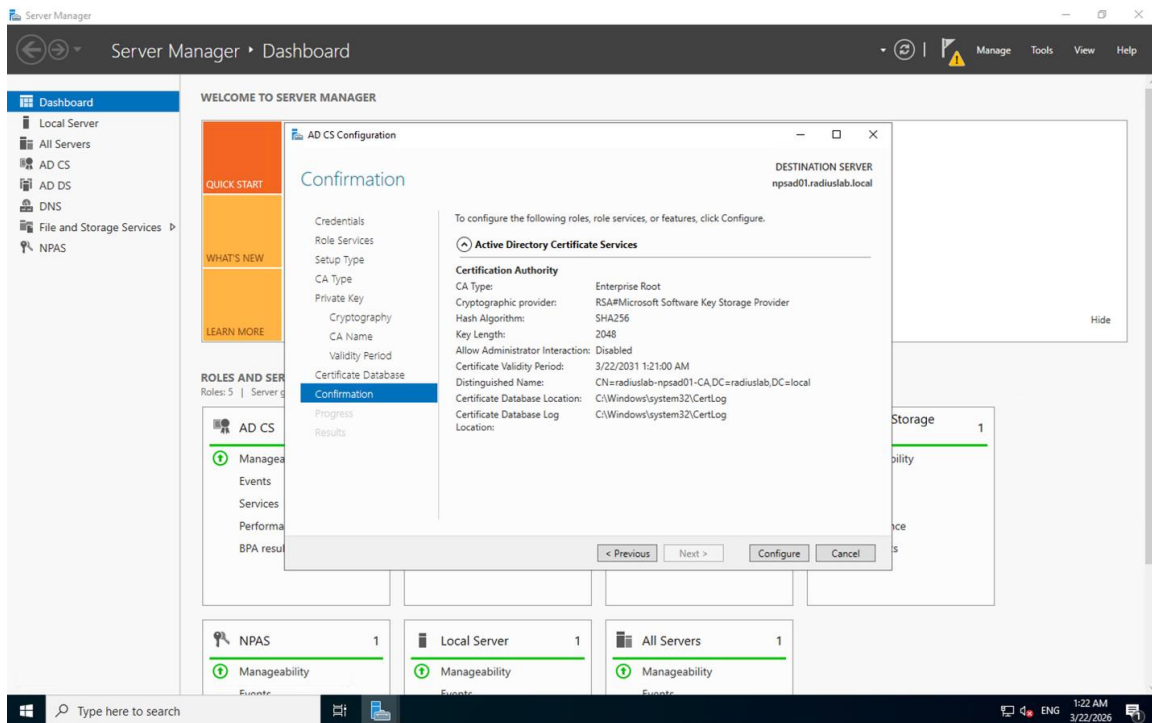
[Screenshot- NPS RADIUS Clients showing NAS-Linux at 10.20.3.4 with properties open]

3.1.2.3 Certificate Authority and Certificate Issuance

a) Certificate Authority Configuration

The Certificate Authority was configured using the AD CS Configuration wizard in Server Manager. The confirmation page displayed the finalized configuration settings before completion:

- CA Type: Enterprise Root
- Cryptographic Provider: RSA with SHA256
- Key Length: 2048 bits
- Distinguished Name: CN=radiuslab-npsad01-CA, DC=radiuslab, DC=local
- Certificate Validity Period: Until March 22, 2031



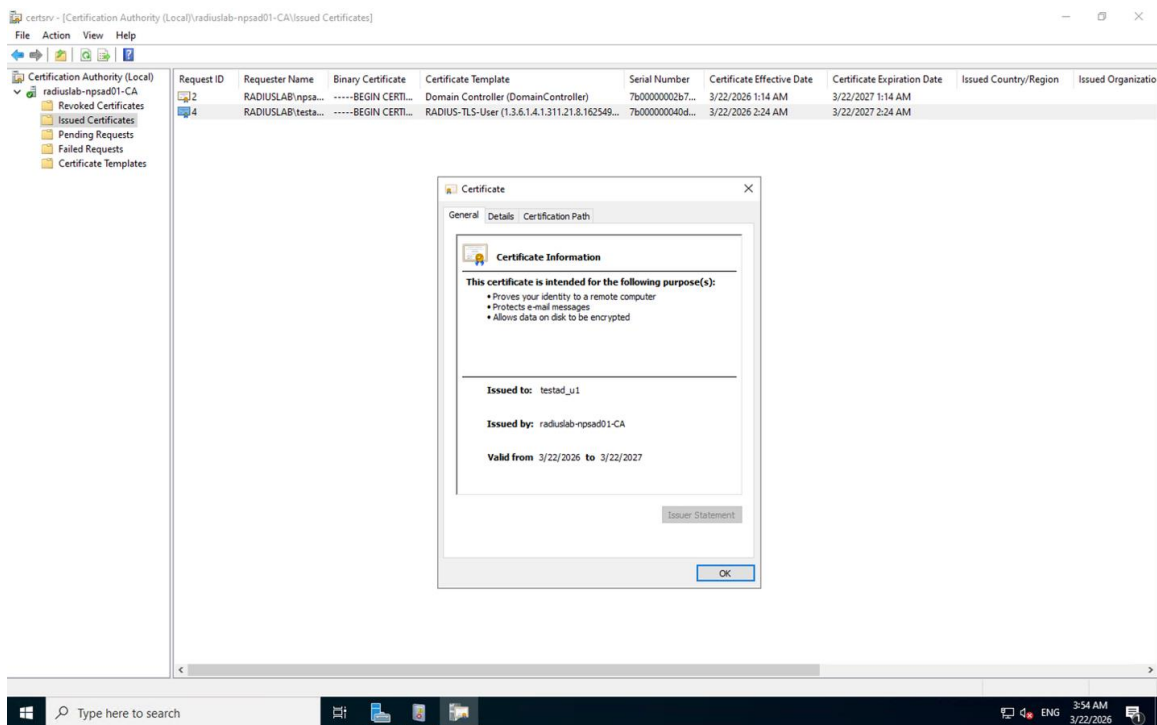
[Screenshot- AD CS Configuration confirmation showing Enterprise Root CA settings on npsad01.radiuslab.local]

b) Certificate Issuance

A Certificate Authority named radiuslab-npsad01-CA was configured on the NPS/Active Directory server. This CA is responsible for issuing and managing all certificates used in the EAP-TLS authentication process, including both server and user certificates.

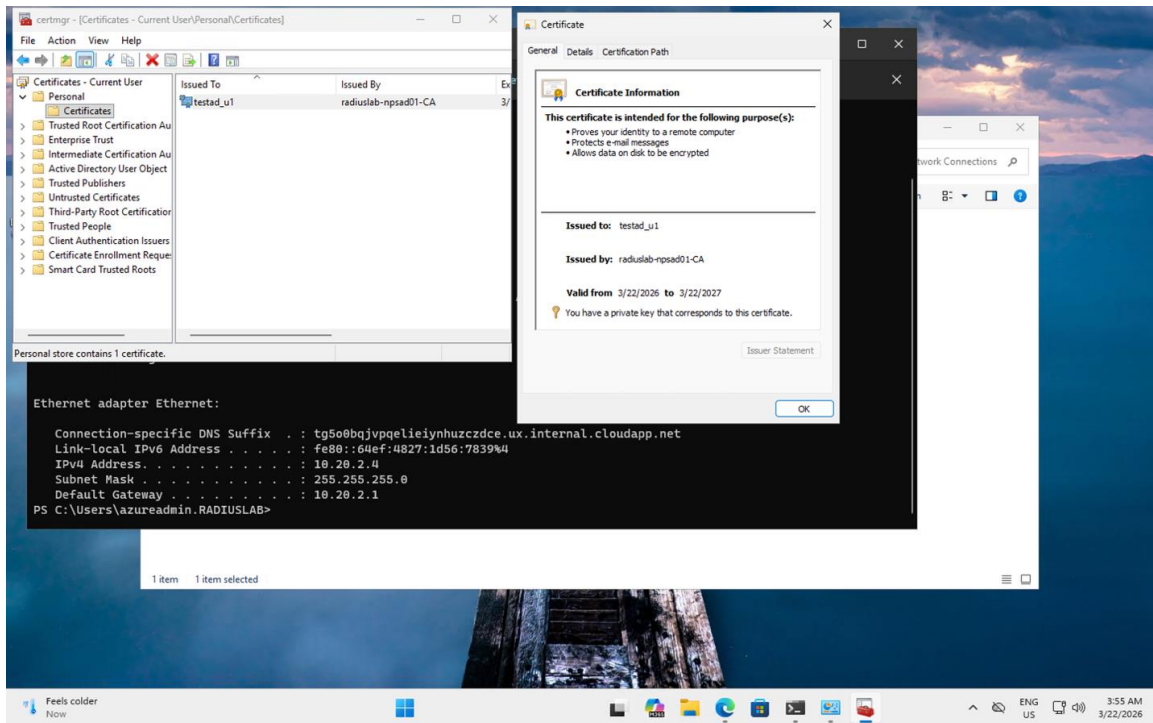
A user certificate was issued to the domain user testad_u1 using the RADIUS-TLS-User certificate template with the following details:

- Issued To: testad_u1
- Issued By: radiuslab-npsad01-CA
- Validity Period: March 22, 2026 to March 22, 2027



[Screenshot- Certificate Authority showing issued certificates including the RADIUS-TLS-User certificate for testad_u1]

The certificate was also verified on the client machine using the certificate manager (certmgr). It appeared in the Personal certificate store with an associated private key, confirming successful certificate enrollment on the client side.

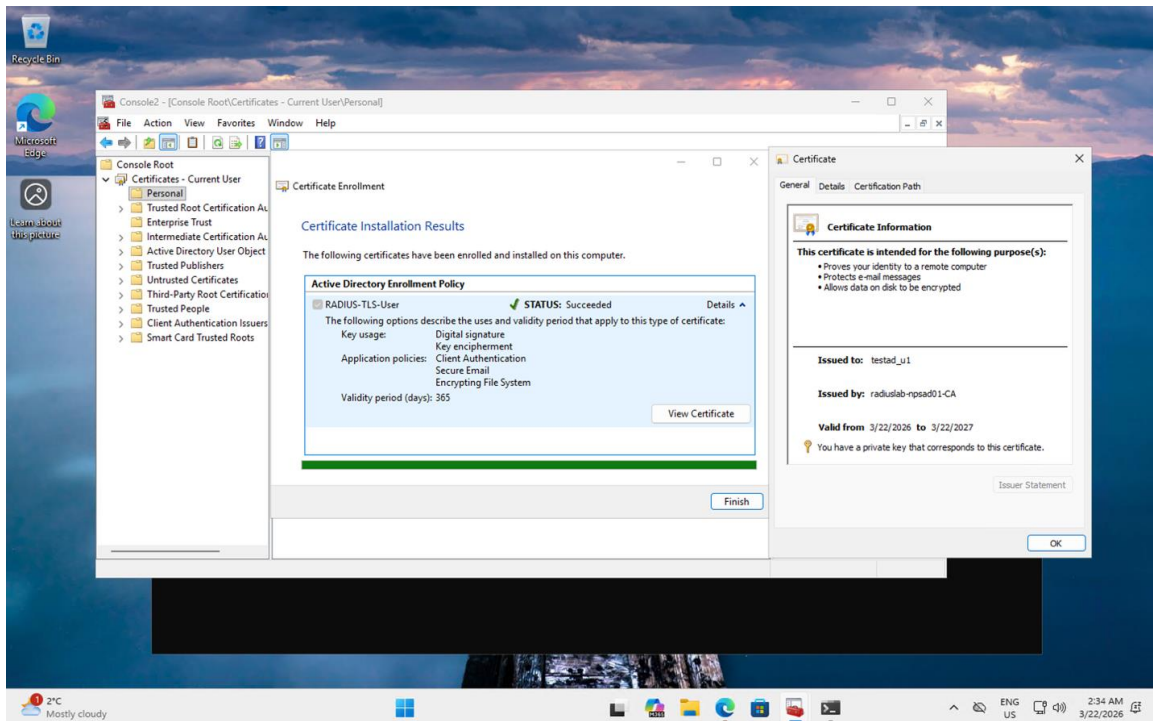


[Screenshot- certmgr showing testad_u1 certificate in Personal store issued by radiuslab-npsad01-CA, with client IP 10.20.2.4 confirmed in PowerShell]

c) Certificate Enrollment (Client Side)

Certificate enrollment was successfully completed on the client virtual machine. The Certificate Enrollment wizard confirmed that the RADIUS-TLS-User certificate was installed with the following properties:

- Key Usage: Digital Signature, Key Encipherment
- Application Policies: Client Authentication, Secure Email, Encrypting File System
- Validity Period: 365 days



[Screenshot- Certificate Installation Results showing RADIUS-TLS-User status as Succeeded with full certificate details]

3.1.2.4 NPS Network Policy - EAP-TLS Configuration

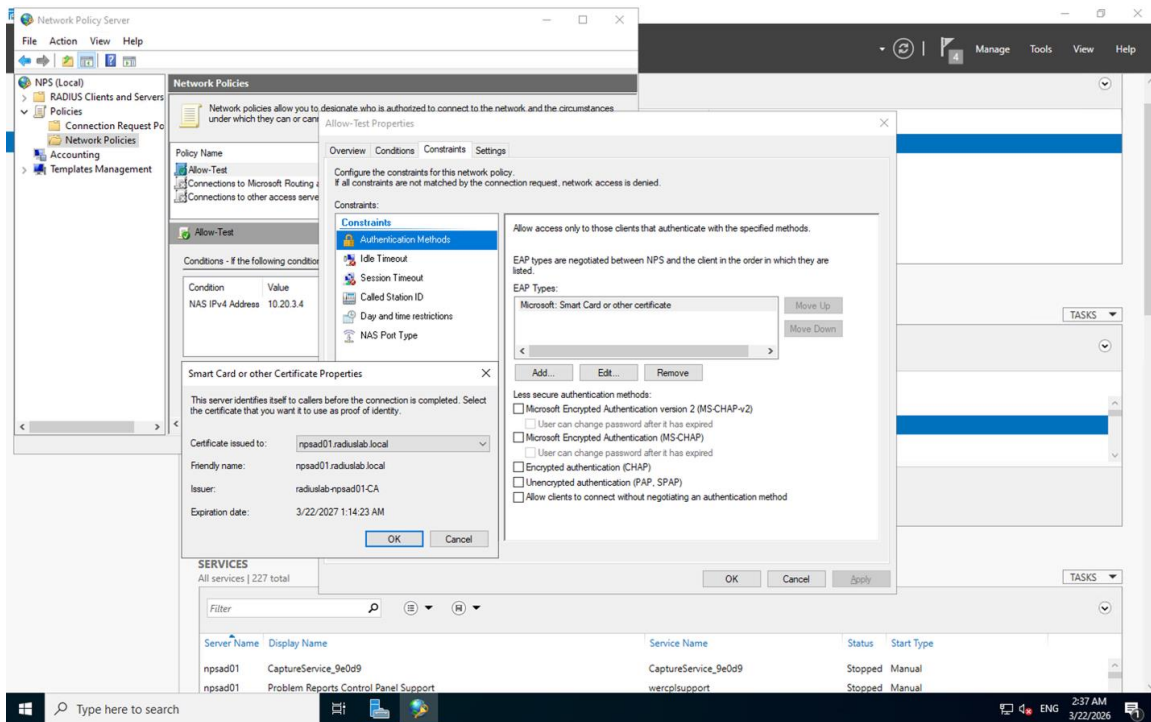
h) EAP-TLS

The NPS network policy named Allow-Test was configured to enforce EAP-TLS as the only permitted authentication method.

The configuration included the following settings:

- EAP Type: Microsoft: Smart Card or other certificate (EAP-TLS)
- Condition: NAS IPv4 Address = 10.20.3.4
- All weaker authentication methods disabled: PAP, CHAP, MS-CHAP, and MS-CHAPv2 were unchecked

This configuration ensures that the NPS server only accepts certificate-based EAP-TLS authentication. Any client attempting to authenticate using PAP or other weaker methods will be rejected.



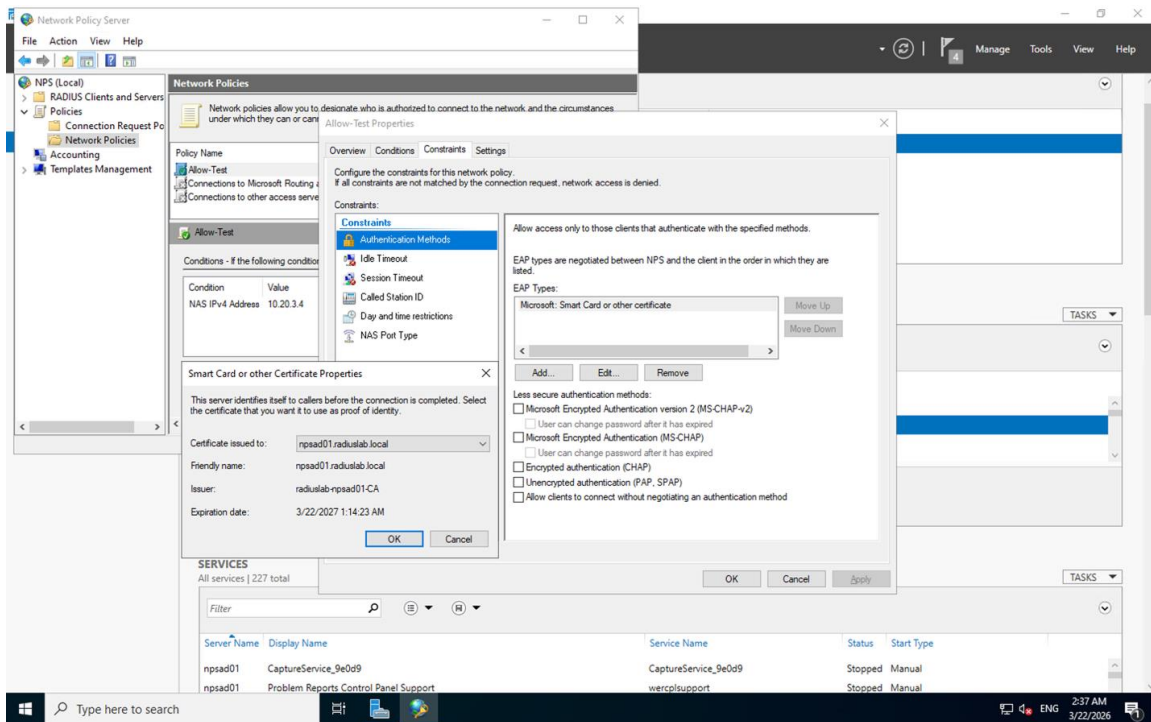
[Screenshot- NPS Allow-Test policy Constraints tab showing EAP-TLS (Smart Card or other certificate) as the only EAP type, with all weaker methods including PAP, CHAP, MS-CHAP, and MS-CHAPv2 unchecked]

i) 802.1X Supplicant Configuration on Client VM

On the client virtual machine vm-client-01, the Ethernet adapter was configured to use IEEE 802.1X authentication. In the Ethernet Properties, the Authentication tab was set as follows:

- Enable IEEE 802.1X authentication: enabled
- Authentication method: Microsoft: Smart Card or other certificate (EAP-TLS)
- Remember credentials: enabled

This configuration confirms that the client-side supplicant was properly set up to use EAP-TLS with the enrolled certificate. However, because the client is connected through a virtual network interface in Azure rather than a physical 802.1X-capable switch or access point, the full EAP-TLS authentication handshake could not be initiated in this environment.



[Screenshot- Client VM Ethernet Properties showing IEEE 802.1X enabled with Smart Card or other certificate selected as the authentication method]

3.1.3 Final System Behavior

Once configuration is complete:

- The client attempts to connect using 802.1X authentication
- The request is forwarded by the NAS to the RADIUS server
- The NPS server validates the client certificate using the Certificate Authority
- If valid, an Access-Accept response is returned
- If invalid or unsupported (e.g., PAP), the request is rejected

This ensures only certificate-based authentication (EAP-TLS) is permitted.

a) Live enterprise deployment

In this project, the core infrastructure was fully configured and validated in a simulated Azure environment. The following describes how this same system would function as a live enterprise deployment, and how each component would be configured in practice.

Supplicant

(Client Devices)

In the lab, the client certificate was manually enrolled on vm-client-01 using the Certificate Enrollment wizard. In a real deployment, this process would be automated through Group Policy (GPO). The domain administrator would configure an Auto-Enrollment policy under *Computer Configuration* → *Windows Settings* → *Security*

Settings → *Public Key Policies*, which instructs all domain-joined machines to automatically request and install a certificate from the CA when they join the domain or at the next Group Policy refresh. The client would never need to manually request a certificate, it would appear silently in the machine's Personal certificate store, ready for 802.1X authentication.

The 802.1X supplicant itself would also be configured via GPO under *Computer Configuration* → *Windows Settings* → *Security Settings* → *Wired/Wireless Network Policies*, pushing the EAP-TLS authentication method and the correct SSID to every managed device automatically.

Authenticator

(Access Points or Switches)

In the lab, vm-nas-01 acted as a software-based stand-in for the authenticator. In production, this role is filled by one or more physical Wi-Fi access points or 802.1X-capable switches. Each authenticator must be configured with:

- The IP address of the RADIUS server (the NPS server)
- A shared secret that matches exactly what is configured in NPS for that client
- WPA2-Enterprise (or WPA3-Enterprise) mode enabled on the SSID
- 802.1X as the authentication framework

The authenticator does not inspect or validate credentials itself. Its only job is to intercept the client's connection attempt, initiate the EAP exchange, and forward RADIUS Access-Request packets to the NPS server. Based on the Access-Accept or Access-Reject response it receives back, it either opens or blocks the port for that device.

Authentication Server

(NPS + Active Directory + CA)

The NPS server, Active Directory domain, and Certificate Authority configured in this project require no structural changes for a real deployment. The NPS network policy (Allow-Test in the lab) would be renamed and scoped appropriately, but the logic is identical: only EAP-TLS is permitted, the client must present a valid certificate issued by the trusted CA, and the certificate must map to a valid Active Directory account.

The Full EAP-TLS Authentication Flow in Production

When a domain device connects to the corporate Wi-Fi, the following happens automatically:

1. The client sends an EAP-Start message to the access point
2. The access point requests the client's identity and forwards it to NPS as a RADIUS Access-Request

3. NPS initiates a TLS handshake - the server presents its certificate (issued by the CA) to prove its identity to the client
4. The client presents its own certificate (issued by the same CA) to prove its identity to the server - this is the mutual authentication that makes EAP-TLS strong
5. NPS verifies the client certificate against the CA and checks that the associated account exists and is active in Active Directory
6. NPS returns an Access-Accept to the access point, which opens the port and grants the device network access
7. A session key is derived from the TLS handshake and used to encrypt the wireless session

At no point is a password transmitted. The certificate is the credential.

Contrast with PEAP

If the organization instead chose PEAP (which is common and easier to deploy), the process would look similar on the surface but differ significantly underneath. PEAP only requires a server-side certificate - the client authenticates with a username and password inside a TLS tunnel rather than with a certificate of its own. This means:

- No client certificates need to be issued or managed
- Enabling it is simpler: on NPS, check PEAP as an allowed method and configure MS-CHAPv2 as the inner authentication method; on the access point, no changes are needed beyond what WPA2-Enterprise already requires; on the client, the 802.1X supplicant is pointed at the SSID with PEAP and the user enters their Active Directory username and password

The tradeoff is that PEAP still relies on passwords, which can be stolen, guessed, or phished. If a user's Active Directory credentials are compromised, an attacker can authenticate to the network. EAP-TLS eliminates this entirely, a stolen password is useless without the corresponding certificate and private key, which never leave the client device. For most organizations, PEAP is the practical starting point because it requires no PKI and minimal client configuration. EAP-TLS is the higher-security target, justified when the organization has an established CA, manages domain-joined devices centrally, and needs to eliminate password-based network access entirely.

3.2 Security recommendations

This section outlines the security risks associated with different Wi-Fi protocols and authentication methods, along with recommendations to mitigate these risks in a production environment.

The analysis progresses from legacy protocols (WEP, WPA) to modern standards (WPA2, WPA3), and finally evaluates authentication methods used within this project, including PAP and EAP-TLS.

WEP Weakness

As the IV used in encryption is relatively small, there are a limited number of possibilities, leading to IVs eventually being reused. In addition, they were sent in plaintext and were viewable in each packet.

These flaws made it vulnerable to attackers who could, after capturing traffic and analyzing the captured IVs, easily discover the shared key and undo the encryption. WEP was officially retired in 2004 due to its vulnerabilities and major security flaws.

WPA weaknesses

While WPA is more secure than WEP, it still contains elements of WEP due to compatibility requirements with older devices and as such some of the security flaws still exist in WPA. As it also uses RC4 for encryption, it is vulnerable to brute-force attacks and is currently considered outdated and insecure.

WPA2 vulnerabilities

WPA2 became the global standard for Wi-Fi security with enhanced security features and stronger protection through AES-CCMP encryption; however, it is not without vulnerabilities. Routers that are still compatible with WEP and have it enabled cause them to be vulnerable to WEP attacks, which can be fixed by disabling WEP and ensuring that it isn't being used. Weak passwords can be cracked easily by brute force attacks, so configuration of a strong and secure password is key to ensuring that the network remains safe. Routers and devices should be kept up to date with the latest firmware updates as exploits to outdated versions exist.

A serious security flaw with WPA2 exposed a vulnerability at the encryption stage, known as the Key Reinstallation Attack (KRACK). The attacker must be within physical range of both the client and the network, and can trigger, capture, analyze, and manipulate the transmissions during the 4-way handshake to determine the key and break the encryption, allowing them to gain access to the network. This attack is more effective against networks with weak passwords and less likely to succeed when a network has a complex password. Vendors released fixes soon after KRACK was discovered, and many experts argued that the vulnerability would prove difficult to exploit in the real world.

Recommendation:

- Use strong, complex passwords
- Disable legacy protocols such as WEP
- Apply firmware and security updates regularly
- Prefer enterprise authentication (WPA2-Enterprise) over personal mode

WPA3 limitations

WPA3 is more secure than WPA2 but isn't widely adopted due to incompatibility with older devices; due to its complexity, WPA's implementation may also be done improperly or incompletely, leading to vulnerabilities. Many current networks offer a transition or mixed mode where both WPA2 and WPA3 are acceptable, but this can allow attackers to force the network into WPA2 and take advantage of its security flaws.

While WPA3 remains an upgrade over its previous versions, it still contains exploitable vulnerabilities and security concerns that must be properly addressed by the adopting business or organization to ensure that the network remains secure.

While there are fewer improvements in WPA3-Enterprise as WPA2-Enterprise continues to remain a secure method, RADIUS servers are now required to use server certificate validation, preventing man-in-the-middle attackers from impersonating the SSID to gain unauthorized access to the network. During the 4-way handshake, the RADIUS server will present the server certificate which, if recognized by the connecting device as legitimate, will prove the server's authenticity and allow the data to be sent safely.

In addition to wireless encryption protocols, authentication methods also play a critical role in overall network security. The following section evaluates the risks associated with PAP and the advantages of EAP-TLS within the context of this project.

PAP Weakness

In Phase 1 of this project, PAP authentication was used to validate basic RADIUS functionality. However, PAP transmits credentials in a weakly protected format that can be captured and viewed using tools such as Wireshark. This was directly demonstrated during testing, where credentials were observable in captured traffic, highlighting its insecurity in real-world scenarios.

Recommendation:

- Avoid PAP in production environments
- Use EAP-TLS for secure authentication

EAP-TLS Security Advantage

To address the limitations observed in Phase 1, Phase 2 implemented EAP-TLS as the primary authentication method. EAP-TLS provides strong, certificate-based authentication, eliminating the need for passwords. It ensures mutual authentication between the client and server and significantly reduces the risk of credential theft, brute-force attacks, and man-in-the-middle attacks.

Recommendation:

- Implement EAP-TLS for enterprise environments
- Use a properly configured Certificate Authority (CA)
- Enforce strict network policies that disable weaker authentication methods

Conclusion

Secure network design depends not only on selecting strong protocols, but also on proper implementation, configuration, and enforcement of authentication mechanisms. The progression from PAP to EAP-TLS in this project illustrates that transition directly moving from a method that exposes credentials to one that eliminates password reliance entirely through mutual certificate-based authentication.

3.3 Instructions for use

This section demonstrates how the system behaves during authentication and how its functionality was validated through testing.

Testing was conducted in two phases:

- Phase 1 – Local RADIUS testing using NTRadPing and Wireshark to validate basic functionality and observe authentication behavior
- Phase 2 – Enterprise testing using a Linux NAS (radtest) to verify policy enforcement after implementing EAP-TLS

The following subsections present the testing process, observations, and results.

Phase 1

3.3.1 Testing with NTRadPing and Wireshark

NTRadPing was used to simulate a RADIUS Access-Request. Simultaneously, Wireshark was capturing traffic on the loopback interface filtered by `udp.port == 1812`.

The Wireshark capture revealed the following packet details:

Protocol: RADIUS

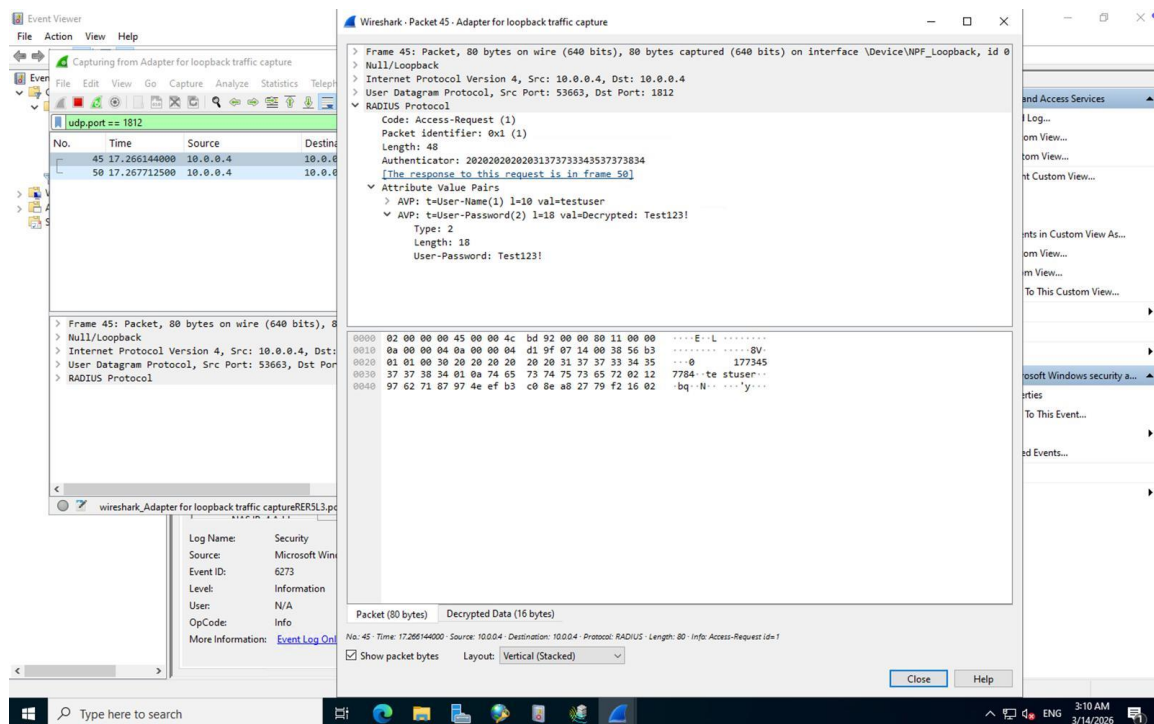
Code: Access-Request (1)

Source/Destination: 10.0.0.4 → 10.0.0.4 (loopback)

UDP Port: 1812

Username (AVP): testuser

Password (AVP): Test123! fully decrypted, confirming PAP



[Screenshot- Wireshark showing RADIUS Access-Request with decrypted username and password]

This is a critical security observation - PAP transmits passwords in a weakly obfuscated form that Wireshark can fully decrypt, making it unsuitable for production environments.

3.3.2 Successful Authentication - Event Viewer

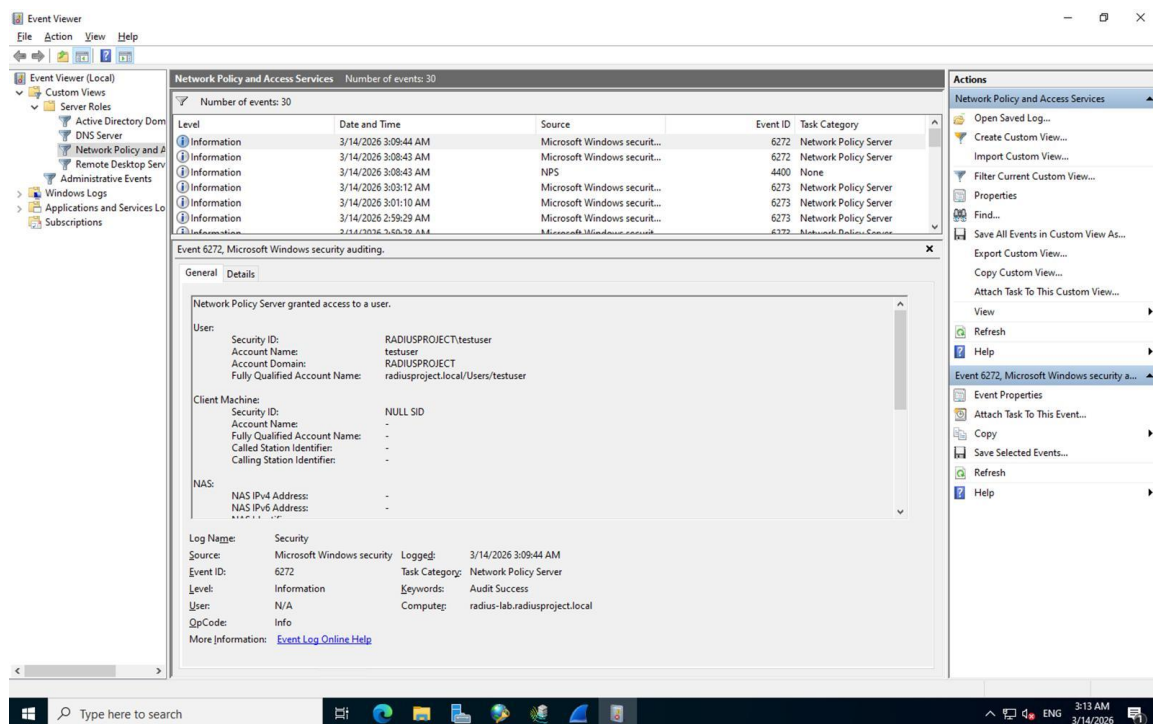
Following the test, Event Viewer under Network Policy and Access Services showed Event ID 6272 confirming the NPS server granted access:

User: RADIUSPROJECT\testuser

Domain: radiusproject.local

Keywords: Audit Success

Server: radius-lab.radiusproject.local



[Screenshot- Event Viewer showing Event ID 6272, Access Granted for testuser]

3.3.3 Confirmed Successful Exchange (NTRadPing + Wireshark)

The final Phase 1 test showed a complete successful RADIUS exchange in Wireshark:

Frame 1: Access-Request

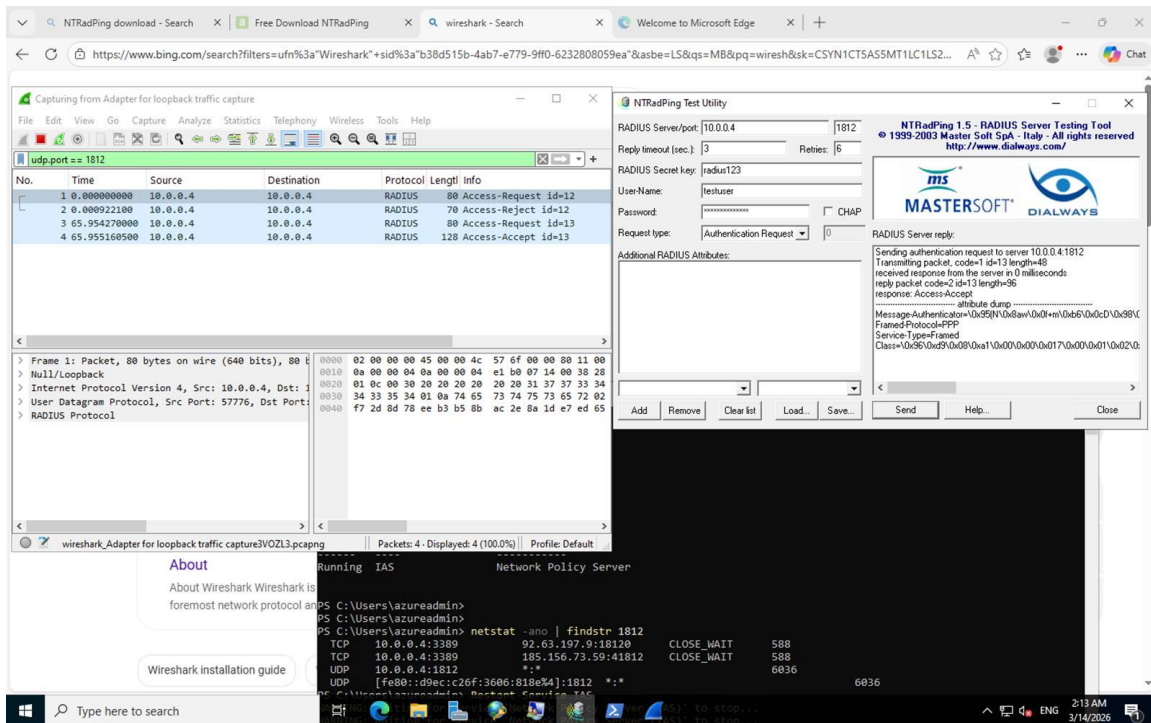
Frame 2: Access-Reject (initial failed attempt)

Frame 3: Access-Request (retry)

Frame 4: Access-Accept

NTRadPing confirmed the server replied with response: Access-Accept along with attributes including Framed-Protocol=PPP and Service-Type=Framed.

PowerShell confirmed NPS was actively listening: UDP 10.0.0.4:1812 *.*



[Screenshot- NTRadPing showing Access-Accept response alongside Wireshark capture and PowerShell netstat confirming port 1812]

3.3.4 Phase 1 Summary

Task	Description
Installed NPS role	Documented with 7 steps showing the full installation wizard
Configured RADIUS client	test-client configured with correct IP (10.0.0.4a) and shared secret
Created user and group	testuser created and added to RadiusUsers group for policy matching
Tested authentication	NTRadPing sent authentication request and Wireshark captured traffic
Proved PAP weakness	Password observed in plain text within Wireshark capture
Confirmed success	Event ID 6272 in Event Viewer indicating access granted
Confirmed full exchange	Access-Accept observed in both NTRadPing and Wireshark; UDP port 1812 verified using netstat

Phase 2

3.3.5 Testing from Linux NAS - radtest Results

The radtest utility was executed from vm-nas-01 (accessed via SSH at 20.151.201.176) to send authentication requests to the NPS server at 10.20.1.4 on UDP port 1812. These tests were used to validate RADIUS communication and observe behavior before and after enforcing EAP-TLS.

Test 1 - Access-Accept

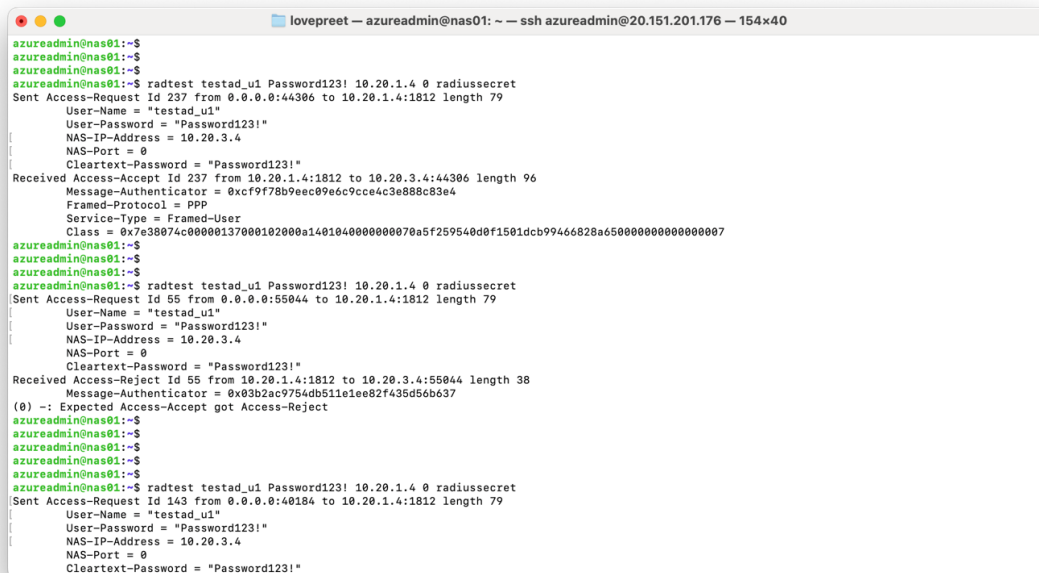
The initial test returned an Access-Accept response. This occurred while the NPS policy was still being finalized, during which PAP authentication was temporarily permitted.

Test 2 - Access-Reject

The second test returned an Access-Reject response after EAP-TLS enforcement was enabled. Since radtest uses PAP and does not support EAP-TLS, the request no longer satisfied the policy conditions. The output indicated: "Expected Access-Accept got Access-Reject."

Test 3 - Access-Reject (Confirmed)

A third test confirmed consistent rejection, verifying that the policy enforcement was functioning correctly and the result was not due to a transient issue.



```
lovepreet — azureadmin@nas01: ~ — ssh azureadmin@20.151.201.176 — 154x40
azureadmin@nas01:~$
azureadmin@nas01:~$
azureadmin@nas01:~$ radtest testad_u1 Password123! 10.20.1.4 0 radiussecret
Sent Access-Request Id 237 from 0.0.0.0:44306 to 10.20.1.4:1812 length 79
[
  User-Name = "testad_u1"
  User-Password = "Password123!"
  NAS-IP-Address = 10.20.3.4
  NAS-Port = 0
  Cleartext-Password = "Password123!"
]
Received Access-Accept Id 237 from 10.20.1.4:1812 to 10.20.3.4:44306 length 96
Message-Authenticator = 0xc9f78b9e0c9e6c9c4c3e888c83e4
Framed-Protocol = PPP
Service-Type = Framed-User
Class = 0x7e38074c00000137000102000a1401040000000070a5f259540d0f1501dcb99466828a65000000000000007
azureadmin@nas01:~$
azureadmin@nas01:~$
azureadmin@nas01:~$ radtest testad_u1 Password123! 10.20.1.4 0 radiussecret
Sent Access-Request Id 55 from 0.0.0.0:55044 to 10.20.1.4:1812 length 79
[
  User-Name = "testad_u1"
  User-Password = "Password123!"
  NAS-IP-Address = 10.20.3.4
  NAS-Port = 0
  Cleartext-Password = "Password123!"
]
Received Access-Reject Id 55 from 10.20.1.4:1812 to 10.20.3.4:55044 length 38
Message-Authenticator = 0x03b2ac9754db511e1ee82f435d56b637
(0) -: Expected Access-Accept got Access-Reject
azureadmin@nas01:~$
azureadmin@nas01:~$
azureadmin@nas01:~$
azureadmin@nas01:~$ radtest testad_u1 Password123! 10.20.1.4 0 radiussecret
Sent Access-Request Id 143 from 0.0.0.0:40184 to 10.20.1.4:1812 length 79
[
  User-Name = "testad_u1"
  User-Password = "Password123!"
  NAS-IP-Address = 10.20.3.4
  NAS-Port = 0
  Cleartext-Password = "Password123!"
]
```

[Screenshot- Linux terminal showing radtest with Access-Accept on first attempt then Access-Reject on subsequent attempts]

3.3.6 Event Viewer - Rejection Confirmed

Event ID 6273 in the NPS logs clearly confirmed the reason for the authentication failure. The event details were as follows:

User: radiuslab.local/testad_u1

Authentication Type: PAP

EAP Type: None (no EAP negotiation occurred)

Client Name: NAS-Linux

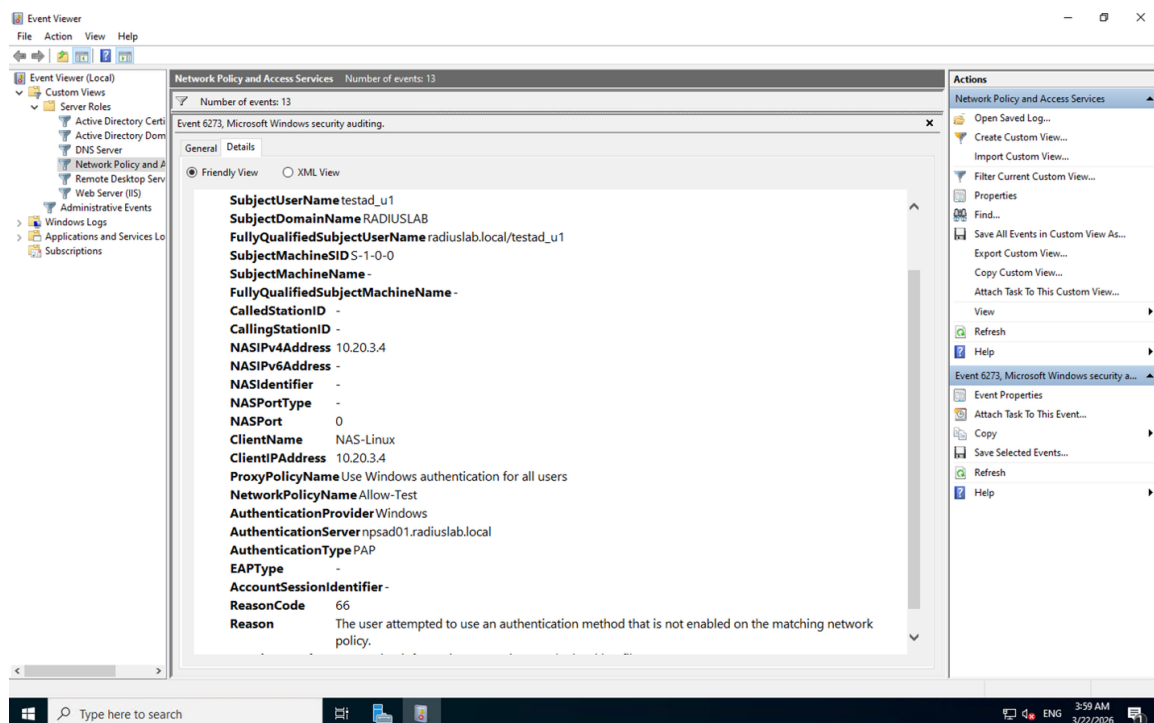
Client IP Address: 10.20.3.4

Network Policy Name: Allow-Test

Reason Code: 66

Reason: The user attempted to use an authentication method that is not enabled on the matching network policy

This confirms that the NPS policy was functioning correctly. The server successfully identified that PAP was not an allowed authentication method under the configured policy and rejected the request accordingly.



[Screenshot- Event Viewer showing Event ID 6273 with ReasonCode 66, AuthenticationType PAP, EAPType blank]

3.3.7 Conclusion: Why Full EAP-TLS Testing Could Not Be Completed

While all backend components were correctly configured, a complete end-to-end EAP-TLS authentication test could not be performed due to the following environmental constraints:

Limitation	Explanation
radtest tool	Only supports PAP; cannot perform EAP-based authentication or TLS handshakes

No physical access point	EAP-TLS over Wi-Fi requires hardware supporting WPA2-Enterprise (802.1X)
No 802.1X supplicant	Requires wpa_supplicant (Linux) or Windows native 802.1X with a client certificate
Azure virtual environment	Cannot fully simulate the client → access point → RADIUS flow without additional hardware

In a real-world deployment with an 802.1X-capable access point and a properly configured supplicant, the system would successfully authenticate users using EAP-TLS.

Conclusion of Testing

Phase 1 confirmed that the basic RADIUS communication flow was operational, though packet analysis exposed PAP's credential weakness. Phase 2 confirmed correct policy enforcement, PAP requests were rejected with Event ID 6273 (Reason Code 66), verifying that only certificate-based EAP-TLS authentication is permitted. All backend components were validated and functioning as intended.

3. References

- Amhiyen, M. (2025, November 21). *WPA2/3-Enterprise with 802.1X authentication: The enterprise standard for secure employee Wi-Fi*. Cloudi-Fi. <https://www.cloudi-fi.com/blog/wpa2-enterprise-802-1x>
- Coppock, J. (2025, September 1). *Wi-Fi Security Comparisons: What Are WEP, WPA, WPA2, and WPA3?*. Avast. <https://www.avast.com/c-wep-vs-wpa-or-wpa2>
- Fortinet, Inc. (n.d.). *Advantages of WPA3-SAE*. Fortinet, Inc. <https://docs.fortinet.com/document/fortiap/7.4.0/wifi-6-7-design-and-planning-guide/355840/advantages-of-wpa3-sae>
- Irei, A. (2025, December 10). *Wireless security: Differences between WEP, WPA, WPA2, WPA3*. TechTarget. <https://www.techtarget.com/searchnetworking/feature/Wireless-encryption-basics-Understanding-WEP-WPA-and-WPA2>
- Kaspersky. (n.d.). *WEP, WPA, WPA2 and WPA3: Differences and explanation*. Kaspersky. <https://www.kaspersky.com/resource-center/definitions/wep-vs-wpa>
- Konchakivskiy, R. (2025, August 6). *WPA2 vs. WPA3: Understanding Wi-Fi security*. Ajax Systems. <https://ajax.systems/blog/wpa2-vs-wpa3-understanding-wi-fi-security/>
- Microsoft. (2025, May 5). *Network Policy Server (NPS) overview*. Microsoft Learn. <https://learn.microsoft.com/en-us/windows/server/networking/technologies/nps/nps-top>
- Madhu, L. (2026, January 15). *What is WPA2-PSK, and how to configure it?*. SuperOps. <https://superops.com/tech-hub/what-is-wpa2-psk>
- Mikac, E. (2024, December 23). *What are Encryption Standards? WPA & WPA2*. CBT Nuggets. <https://www.cbtnuggets.com/blog/technology/security/what-are-encryption-standards-WPA-WPA2>
- NetworkLessons. (n.d.) *Wi-Fi Protected Access (WPA)*. NetworkLessons. <https://networklessons.com/wireless/wi-fi-protected-access-wpa>
- NetworkLessons. (n.d.) *WPA and WPA2 4-Way Handshake*. NetworkLessons. <https://networklessons.com/wireless/wpa-and-wpa2-4-way-handshake>
- NetworkLessons. (n.d.) *WPA Key Hierarchy Explained*. NetworkLessons. https://networklessons.com/wireless/wpa-key-hierarchy-explained#Group_Temporal_Key_GTK
- Panda Security. (2025, October 3). *WPA vs. WPA2: Which Is More Secure and How to Switch*. Panda Security. <https://www.pandasecurity.com/en/mediacenter/wpa-vs-wpa2/>
- Portnox. (n.d.) *What is WPA2 Enterprise?*. Portnox. <https://www.portnox.com/cybersecurity-101/network-security/wpa2-enterprise/>

- Rajesh, R. (2025, August 11). *WEP Encryption Explained: How It Worked and Why It Failed*. DEV. <https://dev.to/rijultp/wep-encryption-explained-how-it-worked-and-why-it-failed-23pf>
- SecureW2. (n.d.). *Server Certificate Validation*. SecureW2. <https://securew2.com/solutions/server-certificate-validation>
- Sharma, A. (2025, July 11). *Wifi Protected Access (WPA)*. GeeksforGeeks. <https://www.geeksforgeeks.org/computer-networks/wifi-protected-access-wpa/>
- Vyas, R. (2026, March 7). *What Is Wired Equivalent Privacy (WEP)? | Wi-Fi Security Guide*. SecureW2. <https://securew2.com/blog/what-is-wep-security>
- Wright, G. & Gillis, A. S. (2024, September 30). *What is WPA3 (Wi-Fi Protected Access 3)?*. TechTarget. <https://www.techtarget.com/searchsecurity/definition/WPA3>